

TRƯỜNG ĐẠI HỌC XÂY DỰNG HÀ NỘI
KHOA CÔNG NGHỆ THÔNG TIN
NGÀNH KHOA HỌC MÁY TÍNH



BÁO CÁO BÀI TẬP LỚN
MÔN: AN TOÀN BẢO MẬT THÔNG TIN
CHỦ ĐỀ: Nghiên cứu chức năng đăng ký và tạo
chứng thư số cho người dùng trên EJBCA
Nhóm 1 – Lớp 67CS

GVHD: Th.S Nguyễn Việt Nhật

SVTH: Nguyễn Diệu Anh	0267067
Nguyễn Phúc An	0207867
Phạm Thế Hoài	0009067
Hoàng Trần Huy Hoàng	0009267

Hà Nội, tháng 9, năm 2025

Mục lục

CHƯƠNG 1: TỔNG QUAN VỀ PKI	5
I. Giới thiệu chung về Hạ tầng cơ sở khóa công khai (PKI)	5
1. Vai trò và chức năng	5
2. Các thành phần của một hạ tầng cơ sở khóa công khai	5
3. Cách thức hoạt động của PKI	9
4. Kiến trúc của hệ thống PKI	11
II. Chứng thư số	12
1. Giới thiệu chung	12
2. Chứng nhận X.509	13
3. Chu kỳ sống của chứng thư số	14
4. Các chức năng chính	15
CHƯƠNG 2: TRIỂN KHAI PKI SỬ DỤNG EJBCA ĐỂ ĐĂNG KÝ VÀ TẠO CHỨNG THƯ SỐ	17
I. Giới thiệu về EJBCA	17
1. Đặc điểm kỹ thuật	17
2. Kiến trúc	17
3. Chức năng	18
II. Cài đặt EJBCA	19
1. Cài đặt EJBCA	19
2. Tạo RootCA	25
3. Tạo SubCA	26
4. Cấu hình SSL Sever Profiles	27
5. Phát hành chứng thư cho Sever	30
6. Cấu hình Client Profiles	34
7. Phát hành chứng thư số cho Client	36
III. Triển khai đăng ký và tạo chứng thư số	40
1. Cài đặt Apache Web Server	40
2. Cấu hình SSL 2 chiều	43
CHƯƠNG 3: KẾT LUẬN	46

Hình 1: Mô hình hoạt động của PKI	6
Hình 2: Quá trình xác thực dựa trên CA.....	7
Hình 3: Quy trình cấp phát và sử dụng chứng chỉ số trong PKI	8
Hình 4: Mô hình phân cấp.....	11
Hình 5: Phiên bản 3 của chứng nhận X.509	14
Hình 6: Chu kỳ sống của chứng thư số.....	15
Hình 7: Kiến trúc EJBCA.....	18
Hình 8: Cài đặt EJBCA (Docker)	19
Hình 9: Khởi động EJBCA Community container.....	19
Hình 10: Thông báo bảo mật của FireFox	20
Hình 11: Giao diện web EJBCA RA.....	20
Hình 12: Enrollment with Enrollment code của EJBCA	21
Hình 13: Yêu cầu mở khóa file chứng chỉ SuperAdmin.p12.....	22
Hình 14: Nội dung của file chứng chỉ SuperAdmin.p12	23
Hình 15: Cửa sổ Certificate Manager	24
Hình 16: Giao diện EJBCS Administration (AdminWeb)	24
Hình 17: Giao diện Manage Certificate Authorities	25
Hình 18: Tạo CA	26
Hình 19: RootCA đã được tạo thành công	26
Hình 20: Tạo SubCA	26
Hình 21: SubCA được tạo thành công.....	27
Hình 22: Thêm SSLServerCertificateProfile trong Manage Certificate Profiles.....	27
Hình 23: Điều chỉnh cài đặt	28
Hình 24: Điều chỉnh cài đặt	29
Hình 25: Điều chỉnh cài đặt	29
Hình 26: Chọn CA để sử dụng cấu hình này.....	29
Hình 27: Manage End Entity Profiles	30
Hình 28: Thêm mới 1 End Entity Profiles tên SSLServerEntity	30
Hình 29: Chỉnh sửa cấu hình Entity vừa tạo.....	31
Hình 30: Nhấn Make New Request trong Request new certificate	31
Hình 31: Chọn SSLServerEntity, tạo cặp khóa bởi CA.....	32
Hình 32: Nhập CN, username, Enrollment code và Email.....	32
Hình 33: Tải thông tin về	33
Hình 34: Tải chứng chỉ test-server.p12 về và unlock bằng mật khẩu vừa tạo ở bước trên	34
Hình 35: Tạo ClientProfiles	34
Hình 36: Chỉnh sửa ClientProfiles vừa tạo	35
Hình 37: Chỉnh sửa ClientProfiles vừa tạo	35
Hình 38: Chọn CA	36
Hình 39: Thêm mới một End Entity Profiles.....	36

Hình 40: chỉnh sửa End Entity Profiles	37
Hình 41: EJBCA RA.....	37
Hình 42: Chọn ClientEntity và tạo cặp khoá bởi CA	38
Hình 43: Điền các thông tin CN, username, enrollment code và email	38
Hình 44: Tải thông tin về	39
Hình 45: Sau khi tải chứng chỉ về nhập mật khẩu đã tạo để mở	39
Hình 46: Cài Apache và truy cập localhost.....	40
Hình 47: Cấu hình SSL 1 chiều	41
Hình 48: Kích hoạt module SSL trong Apache	41
Hình 49: Chỉnh sửa cấu hình VirtualHost	42
Hình 50: Tải về file RootCA gốc từ giao diện RA Web	42
Hình 51: Download Certificate	43
Hình 52: Chỉnh sửa cấu hình VirtualHost để cấu hình 2 chiều.....	44
Hình 53: Cảnh báo của firefox	44

CHƯƠNG 1: TỔNG QUAN VỀ PKI

I. Giới thiệu chung về Hạ tầng cơ sở khóa công khai (PKI)

Trong giải pháp ký số, hạ tầng cơ sở công khóa công khai (Public Key Infrastructure – PKI) là hệ thống vừa mang tính tiêu chuẩn, vừa mang tính công nghệ cho phép người dùng trong một mạng công cộng không bảo mật (như Internet), có thể trao đổi thông tin một cách an toàn thông qua việc sử dụng một cặp khóa bí mật và công khai được chứng nhận bởi một nhà cung cấp chứng nhận số CA (Certificate Authority) được tin nhiệm.

Nền tảng khóa công khai cung cấp một chứng chỉ số, dùng để xác minh một cá nhân hoặc một tổ chức, và các dịch vụ danh mục có thể lưu trữ và khi cần có thể thu hồi các chứng chỉ số.

1. Vai trò và chức năng

PKI cho phép người khác tham gia xác thực lẫn nhau. Mục tiêu chính của PKI là cung cấp khóa công khai và xác định mối liên hệ giữa khóa và định danh người dùng. Nhờ vậy mà người dùng có thể sử dụng trong một số ứng dụng như:

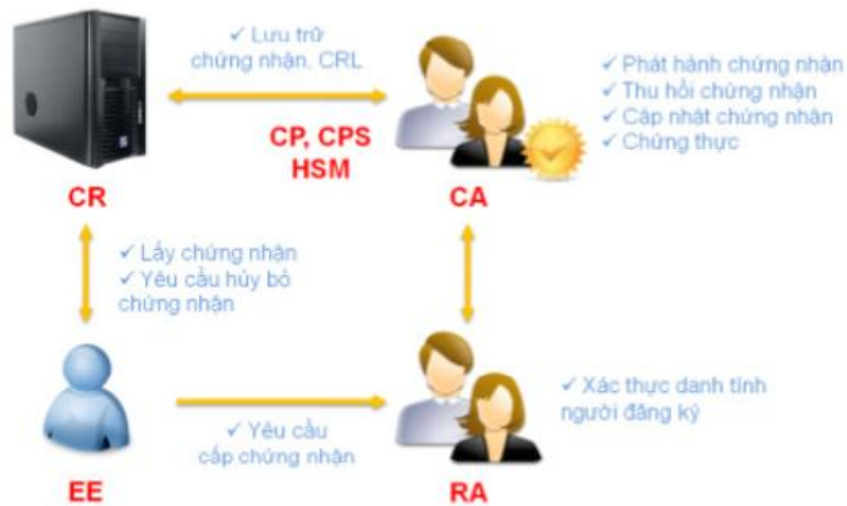
- Mã hóa, giải mã văn bản
- Xác thực người dùng ứng dụng
- Mã hóa email hoặc xác thực người gửi email
- Tạo chữ ký số trên văn bản điện tử

Một PKI phải đảm bảo được các tính chất sau trong một hệ thống trao đổi thông tin:

- **Tính bí mật (Confidentiality):** PKI phải đảm bảo tính bí mật của dữ liệu
- **Tính toàn vẹn (Integrity):** PKI phải đảm bảo dữ liệu không thể bị mất mát hoặc chỉnh sửa và các giao tác không thể bị thay đổi
- **Tính xác thực (Authentication):** PKI phải đảm bảo danh tính của thực thể được xác minh
- **Tính không thể chối từ (Non-Repudiation):** PKI phải đảm bảo dữ liệu không thể bị không thừa nhận hoặc giao tác bị từ chối

2. Các thành phần của một hạ tầng cơ sở khóa công khai

PKI là cơ cấu tổ chức gồm con người, tiến trình, chính sách, thủ tục, phần cứng và phần mềm dùng để phát sinh, quản lý, lưu trữ và thu hồi các chứng nhận khóa công khai.



Hình 1: Mô hình hoạt động của PKI

PKI gồm các thành phần chính sau:

2.1. Thực thể cuối (End Entity – EE)

Đối tượng sử dụng chứng nhận (chứng thư số): có thể là một tổ chức, một người cụ thể hay một dịch vụ trên máy chủ,...

EE gửi yêu cầu cấp chứng chỉ đến RA hoặc CA, sau đó sử dụng chứng chỉ này cho các mục đích như: mã hóa dữ liệu, xác thực danh tính hoặc ký số để bảo đảm tính toàn vẹn và chống chối bỏ trong giao dịch điện tử.

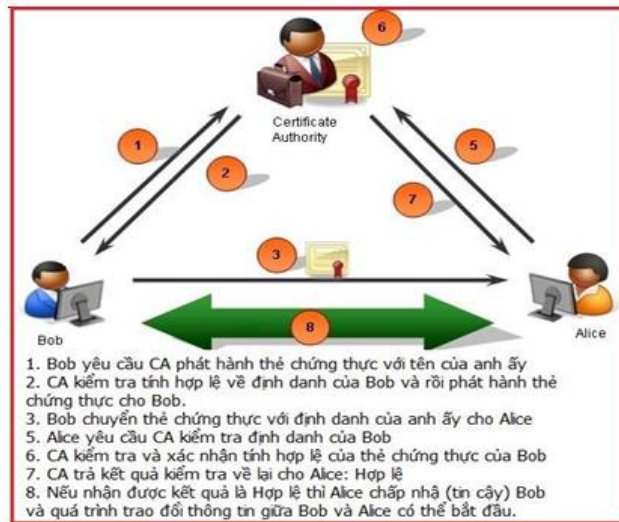
2.2. Tổ chức chứng nhận (Certificate Authority – CA)

CA là một thực thể PKI có trách nhiệm cấp chứng thư số cho các thực thể khác trong hệ thống.

CA cũng được gọi là bên thứ ba được tin tưởng, nó nhận một yêu cầu phát hành (cấp) thẻ chứng thực, từ một tổ chức hoặc một cá nhân nào đó, và phát hành thẻ chứng thực yêu cầu đến họ sau khi xác thực client yêu cầu.

Khi một chứng chỉ không còn hợp lệ, CA cũng sẽ cập nhật vào danh sách chứng chỉ bị thu hồi (CRL) hoặc cung cấp giao thức OCSP để người dùng tra cứu trạng thái chứng chỉ.

Quá trình xác thực dựa trên CA được minh họa như ảnh sau:



Hình 2: Quá trình xác thực dựa trên CA

2.3. Tổ chức đăng ký (Registration Authority - RA)

RA đóng vai trò là trung gian giữa người dùng và CA.

RA tiếp nhận yêu cầu từ người dùng, xác minh danh tính, kiểm tra giấy tờ hoặc thông tin pháp lý, sau đó chuyển thông tin đã xác thực cho CA để phát hành chứng chỉ.

RA không trực tiếp cấp chứng chỉ mà chủ phụ trách khâu xác thực, đảm bảo rằng chỉ những yêu cầu hợp lệ mới được chuyển lên CA.

Mục đích chính của RA là để giảm tải công việc của CA. Chức năng thực hiện của một RA cụ thể sẽ khác nhau tùy theo nhu cầu triển khai PKI nhưng chủ yếu bao gồm các chức năng sau:

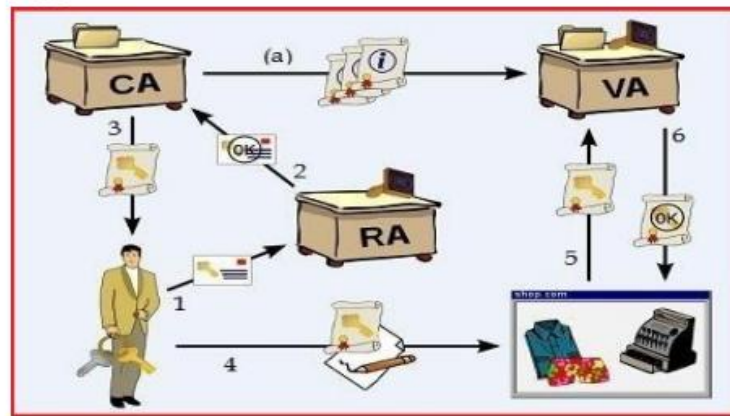
- Xác thực cá nhân, chủ thể đăng ký chứng thư số.
- Kiểm tra tính hợp lệ của thông tin do chủ thể cung cấp.
- Xác nhận quyền của chủ thể đối với những thuộc tính chứng thư số được yêu cầu.
- Kiểm tra xem chủ thể có thực sự sở hữu khóa riêng đang được đăng ký hay không (chứng minh sở hữu).
- Tạo cặp khóa bí mật, công khai. (nếu chủ thể yêu cầu)
- Phân phối bí mật được chia sẻ đến thực thể cuối (ví dụ khóa công khai của CA).
- Thay mặt chủ thể thực thể cuối khởi tạo quá trình đăng ký với CA.
- Lưu trữ khóa riêng.

- Khởi sinh quá trình khôi phục khóa
- Phân phối thẻ bài vật lý (thẻ thông minh)

2.4. Kho lưu trữ chứng chỉ (Certificate Repository - CR)

Đây là nơi công khai lưu trữ các chứng chỉ số đã phát hành và danh sách chứng chỉ bị thu hồi. Nhờ đó, người dùng hoặc các hệ thống khác có thể dễ dàng tra cứu chứng chỉ và kiểm tra tính hợp lệ.

CR cung cấp cơ chế phân phối chứng thư và danh sách thu hồi chứng thư (CRLs - Certificate Revocation Lists).



Hình 3: Quy trình cấp phát và sử dụng chứng chỉ số trong PKI

- (1) : Người dùng gửi yêu cầu phát hành thẻ chứng thư số và khóa công khai của nó đến RA;
- (2) : Sau khi xác nhận tính hợp lệ định danh của người dùng thì RA sẽ chuyển yêu cầu này đến CA;
- (3) : CA phát hành thẻ chứng thư số cho người dùng;
- (4) : Sau đó người dùng “ký” thông điệp trao đổi với thẻ chứng thư số mới vừa nhận được từ CA và sử dụng chúng (thẻ chứng thực số + chữ ký số) trong giao dịch;
- (5) : Định danh của người dùng được kiểm tra bởi đối tác thông qua sự hỗ trợ của VA;

(VA (validation authority) : Cơ quan xác thực của bên thứ ba có thể cung cấp thông tin thực thể này thay mặt cho CA)

- (6) : Nếu chứng thư số của người dùng được xác nhận tính hợp lệ thì đối tác mới tin cậy người dùng và có thể bắt đầu quá trình trao đổi thông tin với nó (VA nhận thông tin về thẻ chứng thư số đã được phát hành từ CA (a))

2.5. Chính sách chứng chỉ (Certificate Policy - CP) và Tuyên bố thực hành chứng thực (Certification Practice Statement - CPS)

PKI còn có các thành phần về quy định chính sách và quy trình.

CP – Chính sách chứng chỉ đưa ra các quy định tổng thể về việc sử dụng chứng chỉ, ví dụ như ai được cấp, phạm vi sử dụng và mức độ tin cậy.

Đi kèm với đó là CPS – Tuyên bố thực hành chứng thực, mô tả chi tiết các quy trình kỹ thuật và biện pháp mà CA áp dụng để thực thi theo CP. CPS giải thích cách thức quản lý khóa, phát hành chứng chỉ và xử lý các tình huống phát sinh liên quan đến bảo mật.

2.6. Mô-đun bảo mật phần cứng (Hardware Security Module – HSM)

Là thiết bị chuyên dụng dùng để bảo vệ khóa bí mật của CA. HSM sinh và lưu trữ khóa riêng trong một môi trường an toàn tuyệt đối, thực hiện các thao tác ký số bên trong thiết bị mà không để khóa rời khỏi hệ thống. Điều này bảo đảm rằng khóa bí mật không bị rò rỉ, đồng thời tăng cường độ tin cậy và an toàn cho toàn bộ hạ tầng PKI.

3. Cách thức hoạt động của PKI

Các hoạt động của PKI bao gồm:

3.1. Khởi tạo thực thể cuối

Trước khi các thực thể cuối có thể tham gia vào các dịch vụ được hỗ trợ bởi PKI, các thực thể này cần phải được khởi tạo trong PKI.

Đăng ký thực thể cuối là một quá trình mà trong đó danh tính của cá nhân được xác minh. Quá trình đăng ký thực thể cuối được thực hiện trực tuyến. Quá trình đăng ký trực tuyến phải được xác thực và được bảo vệ.

3.2. Tạo cặp khóa công khai / khóa bí mật

Người dùng muốn mã hóa và gửi thông báo đầu tiên phải tạo ra một cặp khóa công khai/ khóa riêng. Cặp khóa này là duy nhất đối với mỗi người dùng trong PKI.

Trong mô hình PKI toàn diện, có thể tạo khóa trong hệ thống máy trạm của người dùng cuối hoặc trong hệ thống của CA. Vị trí tạo cặp khóa được xem là quan trọng. Các nhân tố có tác động tới vị trí tạo cặp khóa bao gồm khả năng, hiệu suất, tính đảm bảo, sự phân nhánh hợp pháp và cách sử dụng khóa theo chủ định.

Cho dù là vị trí khóa ở đâu thì trách nhiệm đối với việc tạo chứng thư số chỉ dựa vào CA được cấp quyền. Nếu khóa công khai được tạo bởi thực thể, thì khóa công khai đó phải được chuyển tới CA một cách an toàn.

3.3. Áp dụng chữ ký số để định danh người gửi

Một chữ ký số được đính kèm với thông báo để xác định danh tính người gửi thông báo đó.

Để tạo ra một chữ ký số và đính kèm nó đến thông báo cần thực hiện như sau:

- Biến đổi thông báo ban đầu thành một chuỗi có độ dài cố định bằng cách áp dụng hàm băm trên thông báo. Quá trình này có thể gọi là băm thông báo, chuỗi có độ dài cố định được xem gọi là bản tóm lược thông báo.
- Mã hóa bản tóm lược thông báo bằng khóa riêng của người gửi. Kết quả của bản tóm lược thông báo đã mã hóa là chữ ký số.
- Đính kèm chữ ký số với thông báo ban đầu.

3.4. Mã hóa thông báo

Sau khi áp dụng chữ ký số lên thông báo ban đầu, để bảo vệ nó sử dụng mã hóa. Để mã hóa thông báo và chữ ký số, sử dụng mật mã khóa đối xứng. Khóa đối xứng này được thỏa thuận trước giữa người gửi và người nhận thông báo và chỉ được sử dụng một lần cho việc mã hóa và giải mã.

3.5. Truyền khóa đối xứng

Sau khi mã hóa thông báo và chữ ký số, khóa đối xứng được sử dụng để mã hóa cần truyền đến người nhận. Bản thân khóa đối xứng cũng được mã hóa vì lý do an toàn, nếu bị lộ thì bất kỳ người nào cũng có thể giải mã thông báo.

Do đó, khóa đối xứng sẽ được mã hóa bằng khóa công khai của người nhận. Chỉ có người nhận mới có thể giải mã được khóa đối xứng bằng việc sử dụng khóa riêng tương ứng. Sau khi đã được mã hóa, khóa riêng và thông báo sẽ được chuyển đến người nhận thông báo.

3.6. Kiểm tra danh tính người gửi thông qua một CA

CA đóng vai trò là một bên thứ 3 tin cậy để xác minh danh tính của các thực thể tham gia trong quá trình giao dịch. Khi người nhận nhận bản mã, người nhận có thể yêu cầu CA kiểm tra chữ ký số đính kèm theo bản mã. Dựa trên yêu cầu này, CA kiểm tra chữ ký số của người gửi thông báo.

3.7. Giải mã thông báo và kiểm tra nội dung thông báo

Sau khi nhận thông báo đã được mã hóa, người nhận cần giải mã. Bản mã chỉ có thể được giải mã bằng khóa đối xứng đã được mã hóa. Vì vậy, trước khi giải mã thông báo, khóa đối xứng phải được giải mã bằng khóa riêng của người nhận.

Sau khi đã giải mã khóa đối xứng, khóa đối xứng sẽ được dùng để giải mã thông báo. Chữ ký số đính kèm với thông báo được giải mã bằng khóa công khai của người gửi và bản tóm lược thông báo được bóc tách ra từ nó.

Người nhận sau đó sẽ tạo ra một bản tóm lược thông báo thứ hai. Cả hai thông báo băm sau đó được so sánh để kiểm tra xem có bất kỳ sự giả mạo của thông báo xảy ra trong quá trình truyền tin không. Nếu hai thông báo băm trùng khít nhau chứng tỏ thông báo không bị giả mạo trong khi truyền.

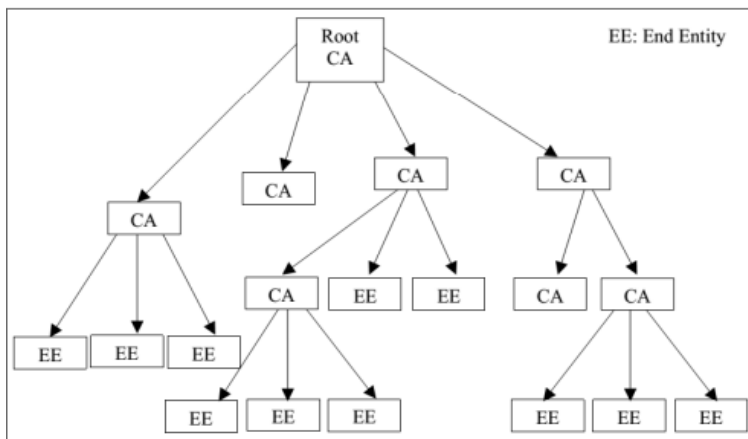
4. Kiến trúc của hệ thống PKI

Hiện nay PKI được triển khai trong nhiều tổ chức như là một công cụ đảm bảo những nguồn tài nguyên nhạy cảm an toàn. Tuy nhiên, với nhiều mục đích khác nhau, tiến trình khác nhau nên khó có thể đưa ra một tiêu chuẩn thiết kế chung. Về cơ bản có các mô hình kiến trúc PKI có dựa trên các mô hình chính: mô hình phân cấp, mô hình mạng lưới, mô hình danh sách tin cậy,...

Ta sẽ tìm hiểu về mô hình phân cấp (hệ thống EJBCA có kiến trúc tuân thủ mô hình CA phân cấp)

4.1. Mô hình phân cấp

Mô hình phân cấp CA có dạng hình cây. RootCA ở mức cao nhất và là gốc tin cậy duy nhất của toàn bộ thực thể bên dưới. Dưới RootCA là các nhánh được mở rộng xuống dưới và là thực thể hoặc một số CA trung gian tạo các đỉnh trong của cây. Các lá của cây là thực thể (thường là end entity)



Hình 4: Mô hình phân cấp

RootCA cấp chứng chỉ cho các CA cấp dưới, các CA cấp dưới lại phát hành chứng chỉ cho người dùng, thiết bị hoặc dịch vụ.

Tất cả các đối tượng đều phải biết khóa công khai của RootCA và tất cả các chứng thư đều có thể kiểm tra bằng cách kiểm tra đường dẫn của chứng thư đó tới RootCA.

Ưu điểm:

- Bảo mật cao: Root CA có thể được giữ offline, giảm nguy cơ bị tấn công.
- Quản lý linh hoạt: Có thể tạo nhiều Intermediate CA cho các mục đích khác nhau (CA cho người dùng nội bộ, CA cho dịch vụ web, CA cho thiết bị IoT...).
- Khả năng mở rộng: Hỗ trợ hệ thống PKI từ quy mô nhỏ đến cực lớn.
- Phân quyền rõ ràng: Root CA giữ vai trò "cấp phép", Intermediate CA thực hiện phát hành.

Nhược điểm:

- Nếu **Root CA** bị lộ khóa bí mật hoặc bị tấn công, toàn bộ hệ thống PKI sẽ mất tin cậy

II. Chứng thư số

1. Giới thiệu chung

Chứng thư số là 1 loại chứng thư điện tử được cấp bởi Tổ chức cung cấp dịch vụ chứng thực chữ ký số, dùng để xác minh danh tính của 1 cá nhân hoặc tổ chức trên môi trường điện tử và chứa khóa công khai của chủ thể đó.

Các thành phần chính của chứng thư số:

- Tên thuê bao: tên của chủ sở hữu chứng thư số (cá nhân, tổ chức)
- Số seri: số hiệu duy nhất của chứng thư số
- Thời gian hiệu lực: khoảng thời gian mà chứng thư số có hiệu lực sử dụng
- Tên tổ chức chứng thực: tên của đơn vị cung cấp dịch vụ chữ ký đã cấp chứng thực
- Chữ ký số của tổ chức chứng thực: chữ ký của tổ chức cấp chứng thư để xác minh nội dung
- Khóa công khai: khóa dùng để xác minh chữ ký số
- Thuật toán mật mã: thuật toán được sử dụng để xác minh chữ ký số
- Hạn chế về phạm vi sử dụng: xác quy định về mục đích và giới hạn sử dụng của chứng thư số

Để khóa công khai của mình được chứng nhận, người dùng phải tạo ra một cặp khóa bất đối xứng và gửi khóa này cho tổ chức CA. Người dùng phải gửi kèm các thông tin về bản thân như tên, địa chỉ. Khi tổ chức CA đã kiểm tra tính xác thực các thông tin của người dùng, CA sẽ phát hành 1 giấy chứng nhận khóa công khai cho người dùng/ Giấy chứng nhận là 1 tập tin nhị phân có thể dễ dàng chuyển đổi qua mạng máy tính.

Tổ chức CA áp dụng chữ ký điện tử của mình cho giấy chứng nhận khóa công khai mà CA đó phát hành. 1 tổ chức CA chứng nhận khóa công khai bằng cách ký nhận chúng. Nếu phía người dùng bên kia tin tưởng vào tổ chức CA thì họ có thể tin vào chữ ký của CA đó.

Một số loại giấy chứng nhận khóa công khai có thể được phát hành như chứng nhận X.509, chứng nhận chất lượng và chứng nhận thuộc tính. Ở đây sẽ tìm hiểu về chứng nhận X.509 bởi vì nó được sử dụng nhiều.

2. Chứng nhận X.509

Chứng nhận X.509 là chứng nhận khóa công khai phổ biến nhất. Có 3 phiên bản

- Phiên bản 1 được hiệp hội Viễn thông quốc tế (International Telecommunications Union - ITU) chỉ định chuẩn X.509 vào năm 1988.
- Phiên bản 2 được phát hành năm 1993 với 2 trường tên nhận dạng duy nhất được bổ sung.
- Phiên bản 3 được bổ sung thêm trường mở rộng đã phát hành vào năm 1997.

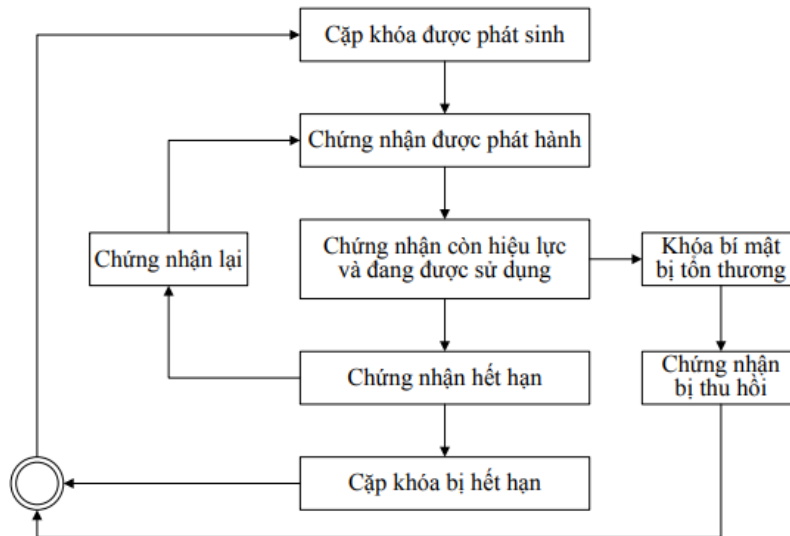
1 chứng nhận khóa công khai kết buộc 1 khóa công khai với sự nhận diện của 1 người (hoặc 1 thiết bị). Khóa công khai và tên thực thể sở hữu khóa này là 2 mục quan trọng trong 1 chứng nhận.

Version
Serial Number
Signature Algorithm
Issuer Name
Validity Period
Subject Name
Public Key
Issuer Unique ID
Subject Unique ID
Extensions
Signature

Hình 5: Phiên bản 3 của chứng nhận X.509

- **Version:** Chỉ định phiên bản của chứng nhận X.509
- **Serial Number:** Số loạt phát hành được gán bởi CA. Mỗi CA nên gán 1 mã số loạt duy nhất cho mỗi giấy chứng nhận mà nó phát hành
- **Signature Algorithm:** Thuật toán chữ ký chỉ rõ thuật toán mã hóa được CA sử dụng để ký giấy chứng nhận. Trong chứng nhận X.509 thường là sự kết hợp giữa thuật toán băm (chẳng hạn như MD5 hoặc SHA-1) và thuật toán khóa công khai (chẳng hạn RSA).
- **Issuer Name:** Tên tổ chức CA phát hành giấy chứng nhận, đây là 1 tên phân biệt theo chuẩn X.500. 2 CA không được sử dụng cùng 1 tên phát hành.
- **Validity Period:** Trường này bao gồm 2 giá trị chỉ định khoảng thời gian mà giấy chứng nhận có hiệu lực. 2 phần của trường này là not-before và not-after
 - Not-before chỉ định thời gian mà chứng nhận này bắt đầu hiệu lực
 - Not-after chỉ định thời gian mà chứng nhận hết hiệu lực
- **Subject Name:** Là 1 X.500 DN, xác định đối tượng sở hữu giấy chứng nhận mà cũng là sở hữu của khóa công khai. 1 CA không thể phát hành 2 giấy chứng nhận có cùng 1 Subject Name.
- **Public key:** Xác định thuật toán của khóa công khai (như RSA) và chứa khóa công khai được định dạng tùy vào kiểu của nó.
- **Issuer Unique ID và Subject Unique ID:** 2 trường này được giới thiệu trong X.509 phiên bản 2, được dùng để xác định 2 tổ chức CA hoặc 2 chủ thể khi chúng có cùng DN.RFC 2459 đề nghị không nên sử dụng 2 trường này.
- **Extensions:** Chứa các thông tin bổ sung cần thiết mà người thao tác CA muốn đặt vào chứng nhận. Trường này được giới thiệu trong X.509 phiên bản 3.
- **Signature:** Đây là chữ ký điện tử được tổ chức CA áp dụng. Tổ chức CA sử dụng khóa bí mật có kiểu quy định trong trường thuật toán chữ ký. Chữ ký bao gồm tất cả các phần trong giấy chứng nhận. Do đó, tổ chức CA chứng nhận cho tất cả các thông tin khác trong giấy chứng nhận chứ không chỉ cho tên chủ thể và khóa công khai.

3. Chu kỳ sống của chứng thư số



Hình 6: Chu kỳ sống của chứng thư số

Trước khi phát hành chứng thư, cặp khóa bí mật/ công khai sẽ được phát sinh. Trong khi chứng thư có hiệu lực và được sử dụng, chứng thư có thể hết hạn hoặc khóa bí mật của người sử dụng bị tổn thương (bị mất hoặc lộ khóa). Trong trường hợp chứng thư hết hạn, cặp khóa cũng sẽ không còn hiệu lực hoặc người sử dụng có thể yêu cầu gia hạn chứng thư cho họ. Trong trường hợp khóa bí mật bị tổn thương, chứng thư sẽ được thu hồi để phát hành chứng thư cho cặp khóa khác.

4. Các chức năng chính

1. Khởi tạo

Trước khi yêu cầu một chứng thư, người dùng phải biết về CA mà mình muốn tham gia. Người dùng phải có địa chỉ của tổ chức CA và kho lưu trữ (nếu tồn tại). Người dùng cũng cần phải có giấy chứng nhận của tổ chức CA và cuối cùng cần phải có cách tạo ra cặp khóa bất đối xứng và lựa chọn các thuộc tính cho tên phân biệt (DN).

2. Yêu cầu chứng thư

Hầu hết các CA sử dụng một trong hai phương thức tiêu chuẩn của yêu cầu chứng nhận: PKCS #10 và CRMF

- **PKCS #10**: Định dạng của thông điệp được gửi đến CA để yêu cầu chứng nhận khóa công khai
- **CRMF**: Định dạng của thông điệp được gửi đến CA để yêu cầu bất cứ trường nào của chứng nhận X.509

2.1. Tạo lại chứng thư

Vì nhiều lý do như giấy chứng nhận hết hạn, thêm thông tin mới vào chứng nhận, xác nhận lại khóa công khai hiện có, hoặc xác nhận khóa mới mà người dùng có thể muốn tạo mới lại chứng nhận của mình. Khi tổ chức CA đáp ứng yêu cầu tạo mới lại này, nó sẽ phát hành cho đối tác một chứng thư mới và có thể xuất bản chứng thư mới này vào kho lưu trữ.

2.2. Hủy bỏ chứng thư

Lý do để hủy một chứng thư là do sự nhận diện được xác nhận bởi CA đã thay đổi.

Danh sách hủy bỏ chứng nhận (Certificate Revocation List – CRL) chứa thông tin thời gian nhằm xác định thời điểm tổ chức CA phát hành nó. CA ký CRL với cùng khóa bí mật được dùng để ký các chứng thư. Các CRL thường được chứa trong cùng kho với các chứng thư nhằm dễ dàng cho việc rút trích. Các CA phát hành các CRL theo định kì, thường là hàng giờ hoặc hàng ngày.

2.3. Lưu trữ và phục hồi khóa

Lưu trữ khóa là một dịch vụ được cung cấp bởi nhiều tổ chức CA. Dùng để tránh trường hợp không giải mã được dữ liệu khi bị mất khóa. Để lưu trữ khóa, người dùng phải gửi khóa bí mật tới nơi lưu trữ. Bởi vì các yêu cầu lưu trữ hay khôi phục khóa đều phải được xác minh nên người sử dụng không thể thao tác trực tiếp đến nơi lưu trữ mà phải thông qua CA phát hành chứng nhận đó.

CHƯƠNG 2: TRIỂN KHAI PKI SỬ DỤNG EJBCA ĐỂ ĐĂNG KÝ VÀ TẠO CHỨNG THƯ SỐ

I. Giới thiệu về EJBCA

EJBCA là sản phẩm mã nguồn mở của hãng Primekey. Đây là một CA được xây dựng trên công nghệ Java J2EE, nhờ đó hiệu suất hoạt động cũng như khả năng tùy biến của CA là tương đối cao so với các hệ thống mã nguồn mở khác. Bên cạnh đó, EJBCA còn cung cấp tính năng và thành phần (OCSP, RA Service, Publisher,...) giúp cấu thành một hệ thống PKI tương đối đầy đủ và hoàn thiện.

1. Đặc điểm kỹ thuật

Được xây dựng dựa trên Java, EJBCA thực sự là một nền tảng độc lập, chạy trên hầu như toàn bộ các phần cứng phổ biến cũng như các hệ điều hành thông dụng như Window, Linux.

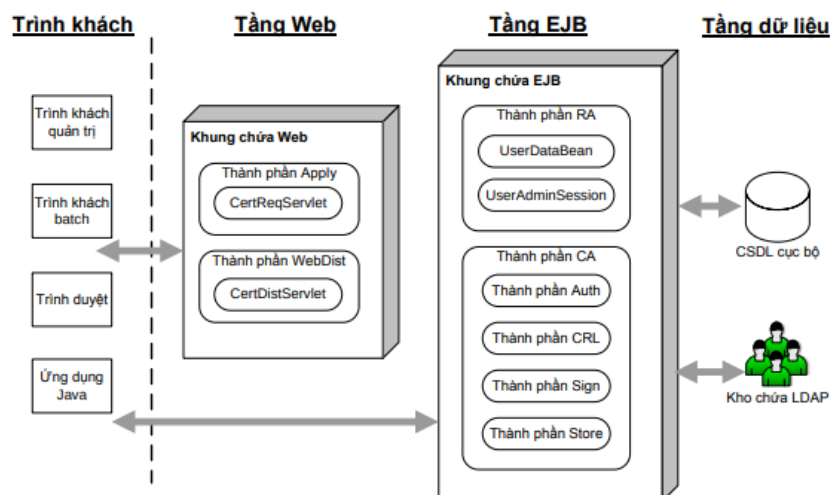
Để có thể hoạt động, EJBCA cần chạy trên một nền tảng máy chủ ứng dụng (Application Server) cũng như một hệ thống Cơ sở dữ liệu nhất định.

Về mặt này, EJBCA cũng hỗ trợ hầu hết các nền tảng App Server phổ biến hiện nay như: JBOSS – Oracle Weblogic – IBM Web Sphere... cũng như các hệ cơ sở dữ liệu từ miễn phí đến trả phí: MySQL, Oracle, IBM DB2, MS SQL,...

Bên cạnh đó, EJBCA còn có một số điểm đặc trưng sau:

- Cung cấp khả năng xây dựng CA theo nhiều mức, không giới hạn số lượng CA;
- Hỗ trợ thuật toán RSA với độ dài khóa lên tới 4096 bits;
- Hỗ trợ các thuật toán DSA với độ dài khóa lên tới 1024 bits;
- Hỗ trợ các hàm băm như MD5, SHA-1, SHA-256;
- Chứng thư được phát hành tuân thủ nghiêm ngặt chuẩn X509.

2. Kiến trúc



Hình 7: Kiến trúc EJBCA

- **Tầng dữ liệu (Data Tier):** Tầng dữ liệu lưu trữ các chứng nhận, CRL cũng như các thực thể cuối. EJBCA sử dụng một cơ sở dữ liệu mặc định để lưu trữ các thực thể cuối. Các chứng nhận được lưu trữ trong một kho chứa LDAP (Lightweight Directory Access Protocol).
- **Thành phần CA:** Thành phần có chức năng tạo các CA gốc, CA con, chứng nhận, CRL và giao tiếp với kho chứa LDAP để lưu trữ thông tin chứng nhận.
- **Thành phần RA:** Thành phần có chức năng tạo, xóa và hủy bỏ người dùng. Nó giao tiếp với cơ sở dữ liệu cục bộ để chứa thông tin người dùng.
- **Tầng Web:** Đây là giao diện (điển hình là giao diện người – máy bằng đồ họa) để trình khách tương tác với hệ thống EJBCA, đồng thời quy định các cấp độ và phạm vi truy cập thông tin khác nhau cho thực thể cuối.
- **Trình khách:** Trình khách là thực thể cuối hay người sử dụng như trình khách thư điện tử, máy chủ web, trình duyệt web hay cổng VPN. Các thực thể cuối không được phép phát hành chứng nhận đến các thực thể khác, nói cách khác chúng là các nút lá trong PKI.

3. Chức năng

- EJBCA là một tổ chức chứng nhận rất phổ biến hiện đang được sử dụng
- Tùy chọn chọn giữa các thuật toán SHA1 hay SHA256 với RSA và với các kích thước khóa khác nhau như 1024, 2048 và 4096.
- Cung cấp một số tính năng nổi bật về lựa chọn ngôn ngữ trong quá trình cấu hình hệ thống.

- Ngoài ra cũng có thể chọn loại publisher mình muốn như LDAP, thư mục động (AD – Active Directory) hay một kết nối publisher tự làm.
- Sự phát hành của chúng nhận luôn luôn thuộc chuẩn X509
- Việc ký chứng nhận có thể là tự ký (self-signed), CA bên ngoài (external CA) hay CA quản trị (admin CA).

II. Cài đặt EJBCA.

1. Cài đặt EJBCA.

Cài đặt EJBCA (Docker)

```
hoangtranhuyhoang@hoanghoangubuntu:~$ sudo docker pull keyfactor/ejbca-ce
[sudo] password for hoangtranhuyhoang:
Using default tag: latest
latest: Pulling from keyfactor/ejbca-ce
4585bcaef7fc: Pull complete
4f8283d7f366: Pull complete
30fe6d3cf099: Pull complete
Digest: sha256:a7aa1e710781525444788e01b4bbbf48aac08c6262dbe7ad86b67e70cdb53843
Status: Downloaded newer image for keyfactor/ejbca-ce:latest
docker.io/keyfactor/ejbca-ce:latest
hoangtranhuyhoang@hoanghoangubuntu:~$
```

Hình 8: Cài đặt EJBCA (Docker)

Khởi động EJBCA Community container

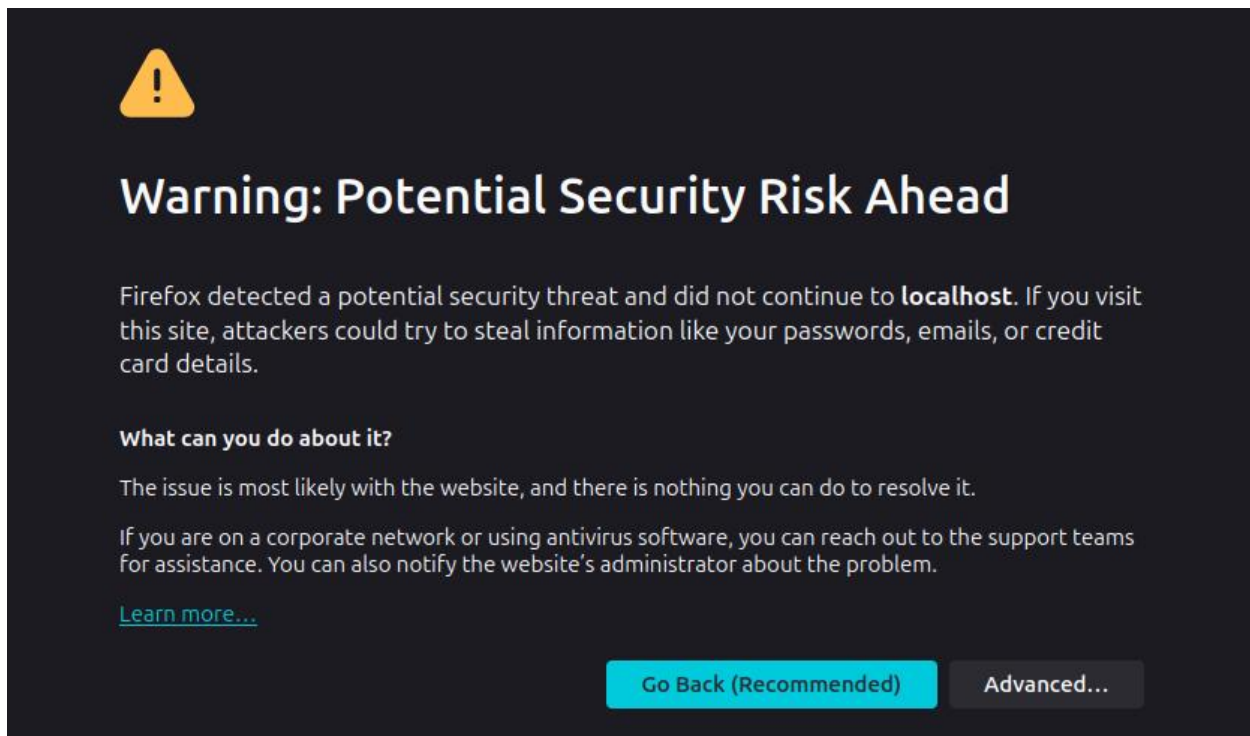
Dùng Lệnh:

```
$ docker run -it --rm -p 80:8080 -p 443:8443 -h localhost -e
TLS_SETUP_ENABLED="true" keyfactor/ejbca-ce
```

```
2025-09-18 16:08:25.311+0000 INFO [/opt/keyfactor/bin/start.sh] (process:1) Health check now reports application status at /ejbca/publicweb/healthcheck/ejbcahealth
2025-09-18 16:08:25.323+0000 INFO [/opt/keyfactor/bin/start.sh] (process:1) *****
2025-09-18 16:08:25.323+0000 INFO [/opt/keyfactor/bin/start.sh] (process:1) *
2025-09-18 16:08:25.323+0000 INFO [/opt/keyfactor/bin/start.sh] (process:1) * A fresh installation was detected and a ManagementCA was created for your initial
2025-09-18 16:08:25.323+0000 INFO [/opt/keyfactor/bin/start.sh] (process:1) * administration of the system.
2025-09-18 16:08:25.323+0000 INFO [/opt/keyfactor/bin/start.sh] (process:1) *
2025-09-18 16:08:25.323+0000 INFO [/opt/keyfactor/bin/start.sh] (process:1) * Initial SuperAdmin client certificate enrollment URL (adapt port to your mapping):
2025-09-18 16:08:25.323+0000 INFO [/opt/keyfactor/bin/start.sh] (process:1) *
2025-09-18 16:08:25.323+0000 INFO [/opt/keyfactor/bin/start.sh] (process:1) * URL: https://localhost:443/ejbca/ra/enrollwithusername.xhtml?username=superadmin
2025-09-18 16:08:25.323+0000 INFO [/opt/keyfactor/bin/start.sh] (process:1) * Password: mvMet55lyKz0p74eIHR8+ah
2025-09-18 16:08:25.323+0000 INFO [/opt/keyfactor/bin/start.sh] (process:1) *
2025-09-18 16:08:25.323+0000 INFO [/opt/keyfactor/bin/start.sh] (process:1) * Once the P12 is downloaded, use "mvMet55lyKz0p74eIHR8+ah" to import it.
2025-09-18 16:08:25.323+0000 INFO [/opt/keyfactor/bin/start.sh] (process:1) *
2025-09-18 16:08:25.323+0000 INFO [/opt/keyfactor/bin/start.sh] (process:1) *****
2025-09-18 16:11:40.463+0000 INFO [org.ejbca.core.ejb.services.ServiceSessionBean] (EJB default - 1) Timer was triggered. Trying to run service with ID 0.
```

Hình 9: Khởi động EJBCA Community container

Truy cập vào phần URL hiển thị ở Console:



Hình 10: Thông báo bảo mật của FireFox

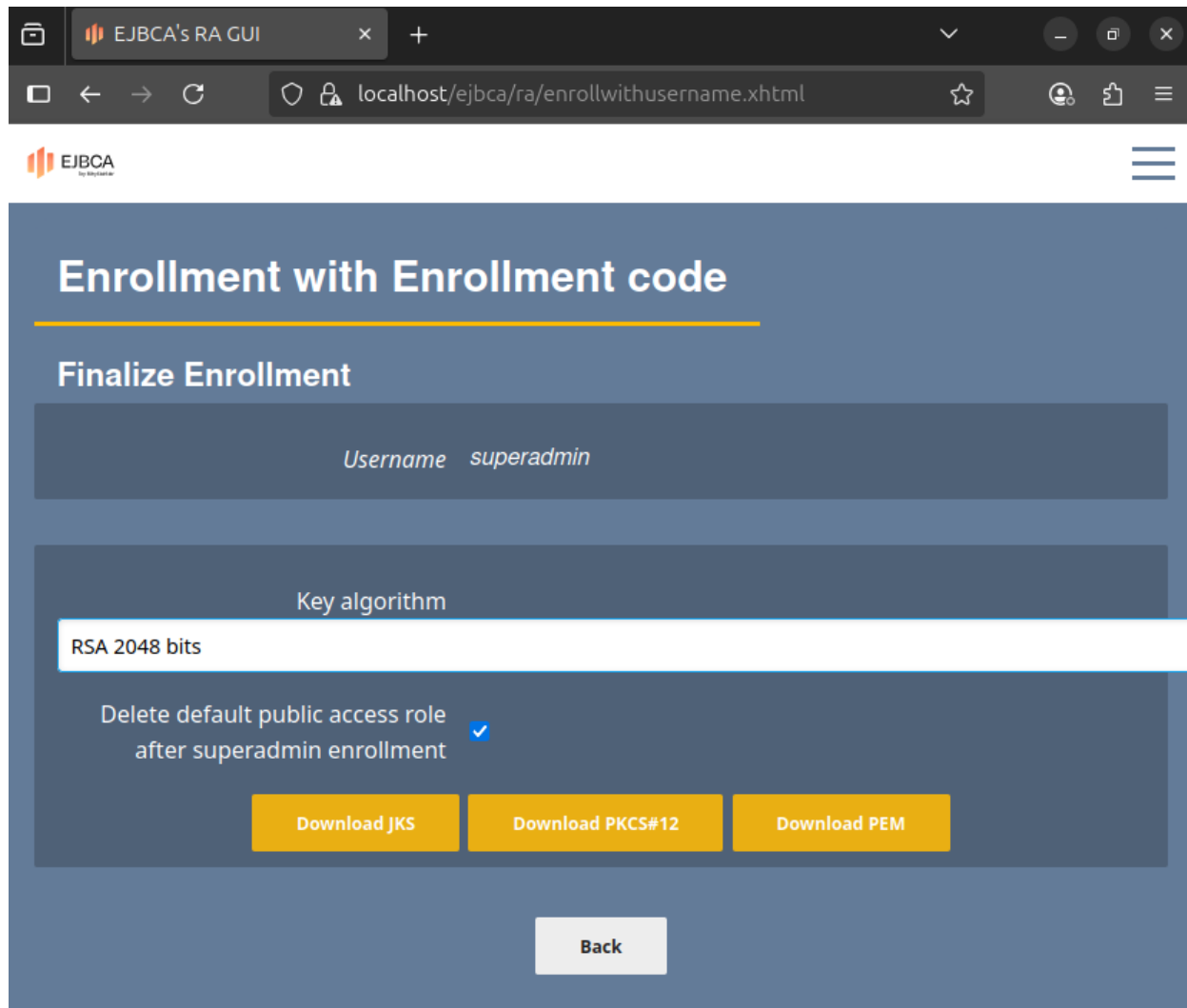
Nhấn Advanced... và Accept the Risk and Continue

Giao diện web EJBCA RA:

Hình 11: Giao diện web EJBCA RA

EJBCA hiện đang hoạt động và đã tạo ra một Management CA (được sử dụng để quản lý PKI nội bộ trong EJBCA) cũng như một siêu quản trị viên có toàn quyền.

Tại web EJBCA RA, trang **Enrollment with Enrollment code (Đăng ký bằng mã đăng ký)**, nhập mật khẩu là phần hiển thị ở output console, sau đó nhấn Check.

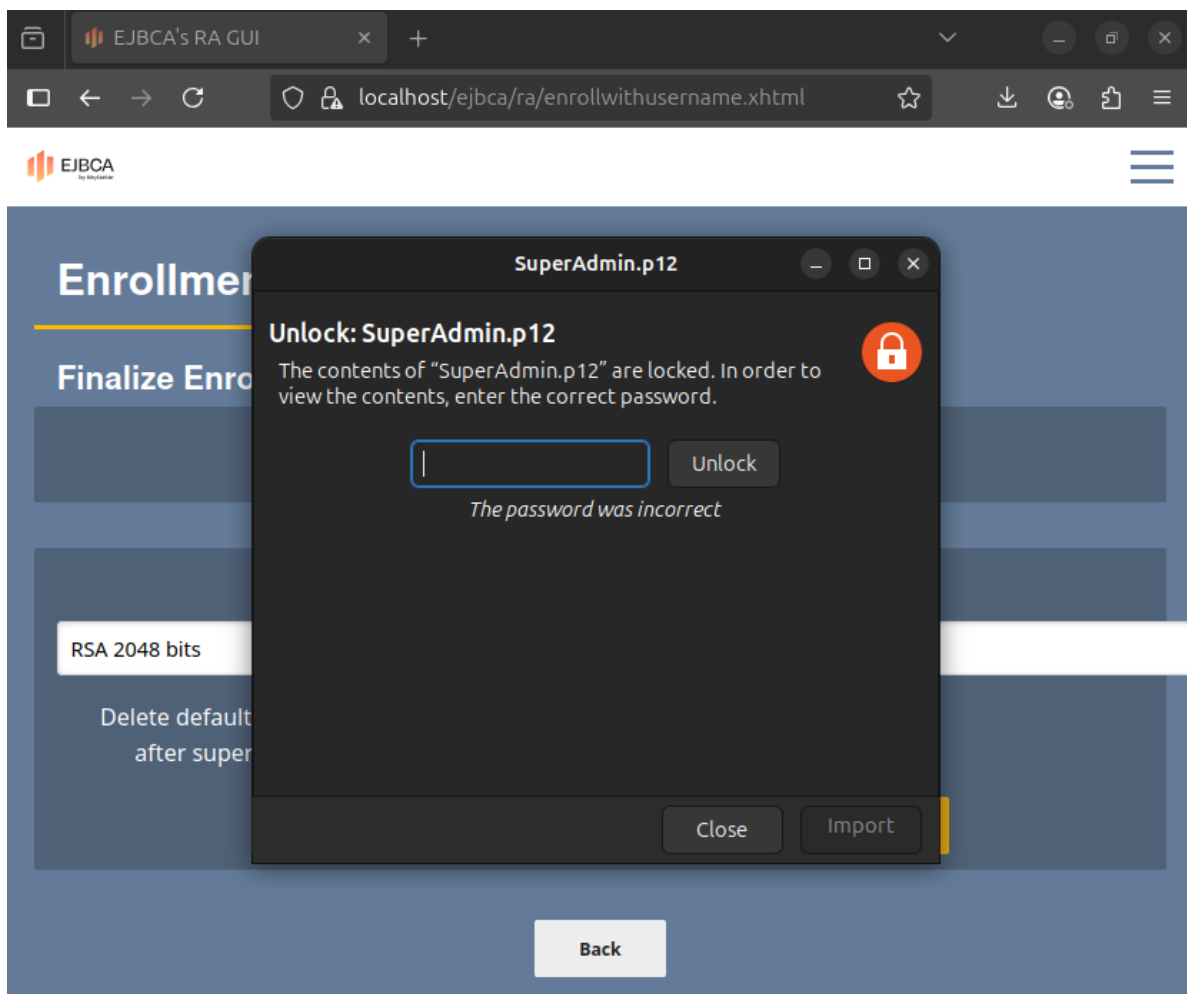


The screenshot displays the EJBCA RA GUI interface. The browser tab is titled 'EJBCA's RA GUI' and the address bar shows 'localhost/ejbca/ra/enrollwithusername.xhtml'. The main heading is 'Enrollment with Enrollment code'. Under the 'Finalize Enrollment' section, the 'Username' field is populated with 'superadmin'. The 'Key algorithm' dropdown menu is open, showing 'RSA 2048 bits' as the selected option. Below this, there is a checkbox labeled 'Delete default public access role after superadmin enrollment' which is checked. At the bottom of the form, there are three yellow buttons: 'Download JKS', 'Download PKCS#12', and 'Download PEM'. A 'Back' button is located at the very bottom center.

Hình 12: Enrollment with Enrollment code của EJBCA

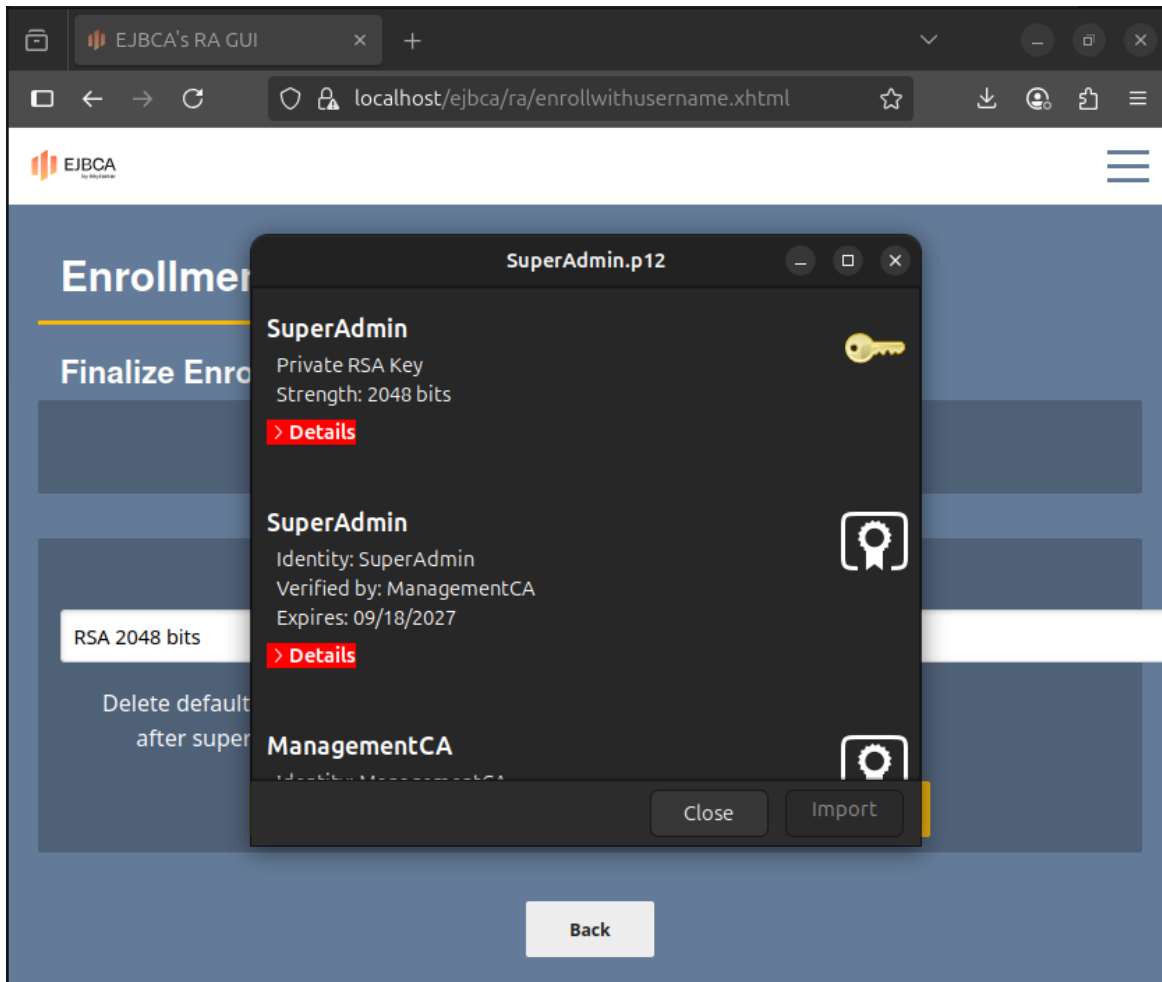
P12 được đề cập trong đầu ra console ở trên là một cặp khóa sẽ được tạo bởi máy chủ EJBCA khi truy cập URL được cung cấp. Định dạng P12 chứa khóa riêng, chứng chỉ được ký bởi Management CA chứa khóa công khai, được mã hóa và bảo vệ bằng mật khẩu.

Chọn thuật toán khoá và độ dài từ danh sách Key algorithm, ở đây sử dụng RSA 2048 bits, sau đó nhấn chọn Download PKCS#12 để tạo file có tên SuperAdmin.p12 và download file này.



Hình 13: Yêu cầu mở khóa file chứng chỉ SuperAdmin.p12

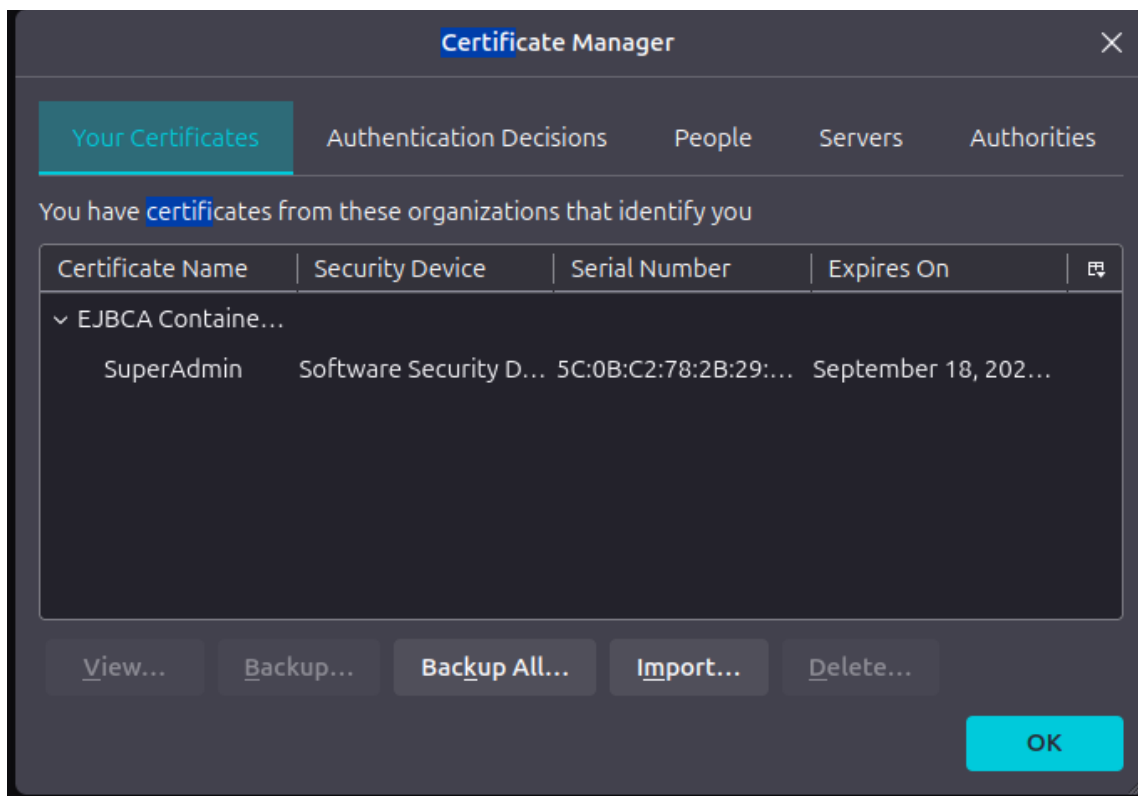
Nhập superadmin.p12 trong trình duyệt web bằng mật khẩu được cung cấp ở phần “Once the P12 is downloaded, use “...” to import it.” trong output console.



Hình 14: Nội dung của file chứng chỉ SuperAdmin.p12

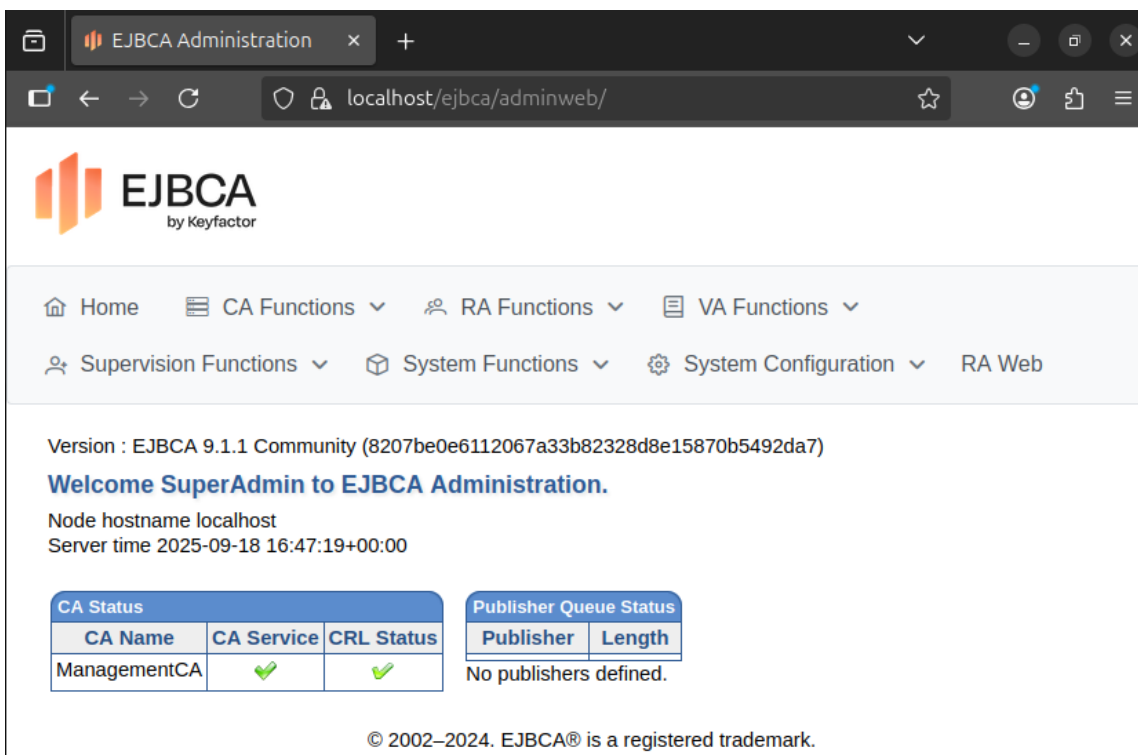
Nhập chứng chỉ vào trình duyệt

Để truy cập EJBCA CA UI, import chứng chỉ SuperAdmin đã tải xuống vào trình duyệt web



Hình 15: Cửa sổ Certificate Manager

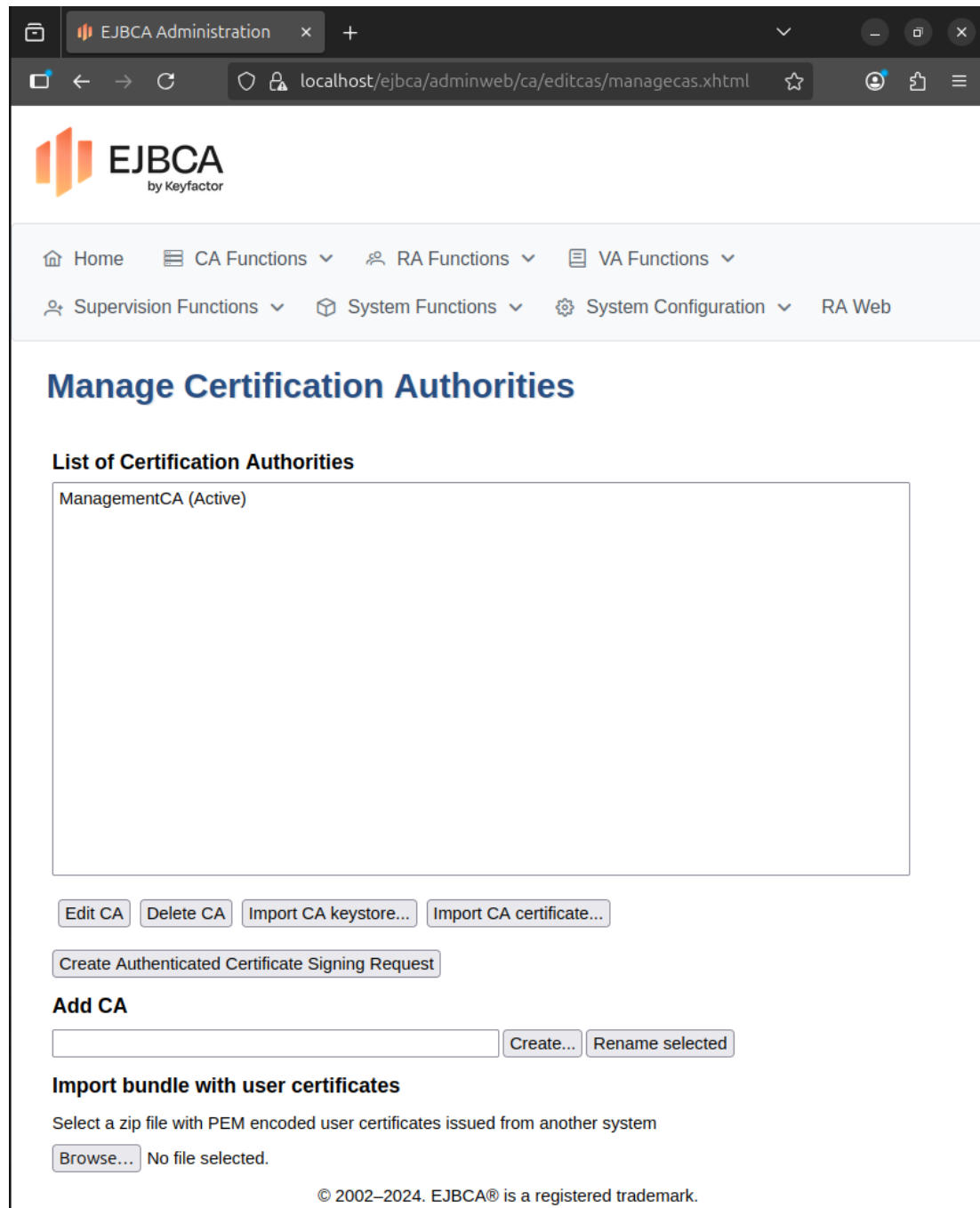
Tiếp theo, trở trình duyệt đến <https://localhost/ejbca/adminweb/> để truy cập EJBCA bằng chứng chỉ đã nhập. EJBCA CA UI mở ra hiển thị trang quản trị.



Hình 16: Giao diện EJBCS Administration (AdminWeb)

2. Tạo RootCA.

Chọn CA Functions -> Certification Authorities



Hình 17: Giao diện Manage Certificate Authorities

Thêm RootCA, sau khi nhấn Create web sẽ chuyển sang trang Create CA

Đặt DN chủ đề, nhà phát hành dạng Self Signed và hồ sơ chứng chỉ là ROOTCA. Hiệu lực của chứng chỉ là 10 năm (10y)

CA Certificate Data	
Subject DN	CN=RootCA, OU=67CS, O=Đại học Xây Dựng Hà Nội DN in string form, e.g. 'CN=My CA,O=MyOrg,C=SE', elements will be ordered according to EJBICA standard. See also the LDAP DN order setting and associated help.
Signed By	Self Signed ▼
Certificate Profile	ROOTCA ▼
Validity (*y *mo *d *h *m *s) or end date of the certificate	10y ISO 8601 date:=[yyyy-MM-dd HH:mm:ssZZ]: '2025-09-18 16:58:43+00:00'.y=365 days, mo=30 days

Hình 18: Tạo CA

Nhấn Create

RootCA đã được tạo và hiện thị trên Manage Certification Authorities

Manage Certification Authorities

List of Certification Authorities

ManagementCA (Active)
RootCA (Active)

Hình 19: RootCA đã được tạo thành công

3. Tạo SubCA.

Cũng trên trang Manage Certification Authorities ở bước trước, tạo thêm SubCA, nhấn Create để chuyển sang trang Create CA.

Đặt DN chủ đề, nhà phát hành dạng là RootCA và hồ sơ chứng chỉ là SUBCA. Hiệu lực của chứng chỉ là 1 năm (1y)

CA Certificate Data	
Subject DN	CN=SubCA, OU=67CS, O=Đại học Xây Dựng Hà Nội DN in string form, e.g. 'CN=My CA,O=MyOrg,C=SE', elements will be ordered according to EJBICA standard. See also the LDAP DN order setting and associated help.
Signed By	RootCA ▼
Certificate Profile	SUBCA ▼
Validity (*y *mo *d *h *m *s) or end date of the certificate	1y ISO 8601 date:=[yyyy-MM-dd HH:mm:ssZZ]: '2025-09-18 17:19:44+00:00'.y=365 days, mo=30 days

Hình 20: Tạo SubCA

Nhấn Create

SubCA đã được tạo và hiển thị trên Manage Certification Authorities

Manage Certification Authorities

List of Certification Authorities

ManagementCA (Active)
RootCA (Active)
SubCA (Active)

Hình 21: SubCA được tạo thành công

4. Cấu hình SSL Sever Profiles

Chọn CA Functions -> Certificate Profiles

Thêm một tên mới SSLServerCertificateProfile trong Manage Certificate Profiles, sau đó nhấn Add.

Manage Certificate Profiles

List of Certificate Profiles

Name	Actions
ENDUSER	View Edit Delete Rename Clone Export
OCSPSIGNER	View Edit Delete Rename Clone Export
ROOTCA	View Edit Delete Rename Clone Export
SERVER	View Edit Delete Rename Clone Export
SUBCA	View Edit Delete Rename Clone Export
SSLServerCertificateProfile	View Edit Delete Rename Clone Export
	Add

Import/Export

Import Profiles from Zip file:

[Browse...](#)

No file selected.

[Import Profiles](#)

[Export Profiles](#)

© 2002–2024. EJBCA® is a registered trademark.

Hình 22: Thêm SSLServerCertificateProfile trong Manage Certificate Profiles

Tìm tên vừa tạo trong danh sách và chọn hành động Edit

Điều chỉnh cài đặt: loại End Entity, mã hoá RSA 2048 bits, hiệu lực 1 năm (1y)

Edit

Certificate Profile: SSLServerCertificateProfile

	Back to Certificate Profiles
Certificate Profile ID	2105862398
Type	<input checked="" type="button" value="End Entity"/> Sub CA Root CA
Available Key Algorithms	ECDSA RSA Ed25519 Ed448 FALCON-512 FALCON-1024 ML-KEM-512 ML-KEM-768 ML-KEM-1024 ML-DSA-44 ML-DSA-65 ML-DSA-87
Available ECDSA curves	No elliptic curve algorithm with selectable curves selected.
Available Bit Lengths	1024 bits 1536 bits 2048 bits 3072 bits 4096 bits
Signature Algorithm	Inherit from issuing CA ▾
Alternative Signature	☐ Use
Validity or end date of the certificate	1y ISO 8601 date: [yyyy-MM-dd HH:mm:ssZZ]: '2025-09-18 17:28:43+00:00' (*y *mo *d *h *m *s) - y=365 days, mo=30 days

Hình 23: Điều chỉnh cài đặt

Ở phần Permissions, bỏ check Allow Key Usage Override

Permissions	
Allow Validity Override	☐ Allow
Allow Expired Validity End Date	☐ Allow
Allow Extension Override	☐ Allow...
Allow certificate serial number override	☐ Allow No unique index for (issuerDN,serialNumber) on database table 'CertificateData'. "Allow certificate serial number override" not allowed.
Allow Subject DN Override by CSR	☐ Allow
Allow Subject DN Override by End Entity Information	☐ Allow
Allow Key Usage Override	☐ Allow
Allow Backdated Revocation	☐ Allow
Use Certificate Storage	☒ Use (disable with caution)
Store Certificate Data	☒ Use (see help for info on usage in combination with 'Use Certificate Storage')

Hình 24: Điều chỉnh cài đặt

Ở phần Key Usage, chọn Digital Signature Key Usage và Key encipherment, tại Extended Key Usage chọn Server Authentication.

X.509v3 extensions	Usages
Key Usage	☒ Use... ☒ Critical ☐ Forbid encryption usage for ECC keys Key Usage: ☒ Digital Signature ☐ Data encipherment ☐ CRL sign ☐ Non-repudiation ☐ Key agreement ☐ Encipher only ☒ Key encipherment ☐ Key certificate sign ☐ Decipher only
Extended Key Usage	☒ Use... ☐ Critical PDF Signing PIV Card Authentication RFC9336 Document Signing SCVP Client SCVP Server SIP Domain SSH Client SSH Server Server Authentication Time Stamping

Hình 25: Điều chỉnh cài đặt

Chọn CA để sử dụng cấu hình này

Available CAs	Any CA ManagementCA RootCA SubCA
---------------	---

Hình 26: Chọn CA để sử dụng cấu hình này

Nhấn Save

5. Phát hành chứng thư cho Sever.

Chọn RA Functions -> End Entity Profiles

Manage End Entity Profiles

List of End Entity Profiles

EMPTY

Edit End Entity Profile

Export End Entity Profile

Delete End Entity Profile

Add End Entity Profile

Add Profile

Rename selected

Clone selected

Import/Export

Import Profiles from Zip file: Browse...

No file selected.

Import

Export Profiles

© 2002–2024. EJBCA® is a registered trademark.

Hình 27: Manage End Entity Profiles

Thêm mới một End Entity Profile tên SSLServerEntity

Add End Entity Profile

SSLServerEntity

Add Profile

Rename selected

Clone selected

Hình 28: Thêm mới 1 End Entity Profiles tên SSLServerEntity

Chọn Entity vừa tạo ở phần danh sách các End Entity Profiles và chọn Edit

Chọn hồ sơ chứng chỉ mặc định là SSLServerCertificateProfile vừa cấu hình ở trên, tiếp theo chọn CA mặc định là SubCA, khóa ở đây do người dùng tạo

Main Certificate Data	
Default Certificate Profile	SSLServerCertificateProfile ▾
Available Certificate Profiles	ENDUSER OCSPSIGNER SERVER SSLServerCertificateProfile SUBCA
Default CA	SubCA ▾
Available CAs Modifying available CAs may affect roles access to this profile	Any CA ManagementCA RootCA SubCA
Default Token	User Generated ▾
Available Tokens	User Generated P12 file BCFKS file JKS file PEM file

Hình 29: Chỉnh sửa cấu hình Entity vừa tạo

Nhấn Save để lưu

Chọn RA Web, nhấn Make New Request trong Request new certificate

EJBCA RA

Request new certificate

Make New Request

Show details

Hình 30: Nhấn Make New Request trong Request new certificate

Trong phần Certificate Type, chọn SSLServerEntity, tạo cặp khoá bởi CA

Make Request

Select Request Template

Certificate Type

SSLServerEntity ▾

Key-pair generation ☒ By the CA
☐ Provided by user
☐ Postpone

Show details

Hình 31: Chọn SSLServerEntity, tạo cặp khóa bởi CA

Nhập CN và username, Enrollment code và Email

Provide request info

Required Subject DN Attributes

Common Name (CN) *

test-server

Provide User Credentials

Username *

test_server

Enrollment code *

....

Confirm enrollment code *

....

Email

0009267@st.huce.edu.vn

Hình 32: Nhập CN, username, Enrollment code và Email

Chọn Download PKCS#12 để tải thông tin về.

Confirm request

Issuer Distinguished Name
CN=SubCA,OU=67CS,0=Đại học Xây Dựng Hà Nội

Subject Distinguished Name
CN=test-server

Public Key Specification

Validity
1y

Show details

Download JKS

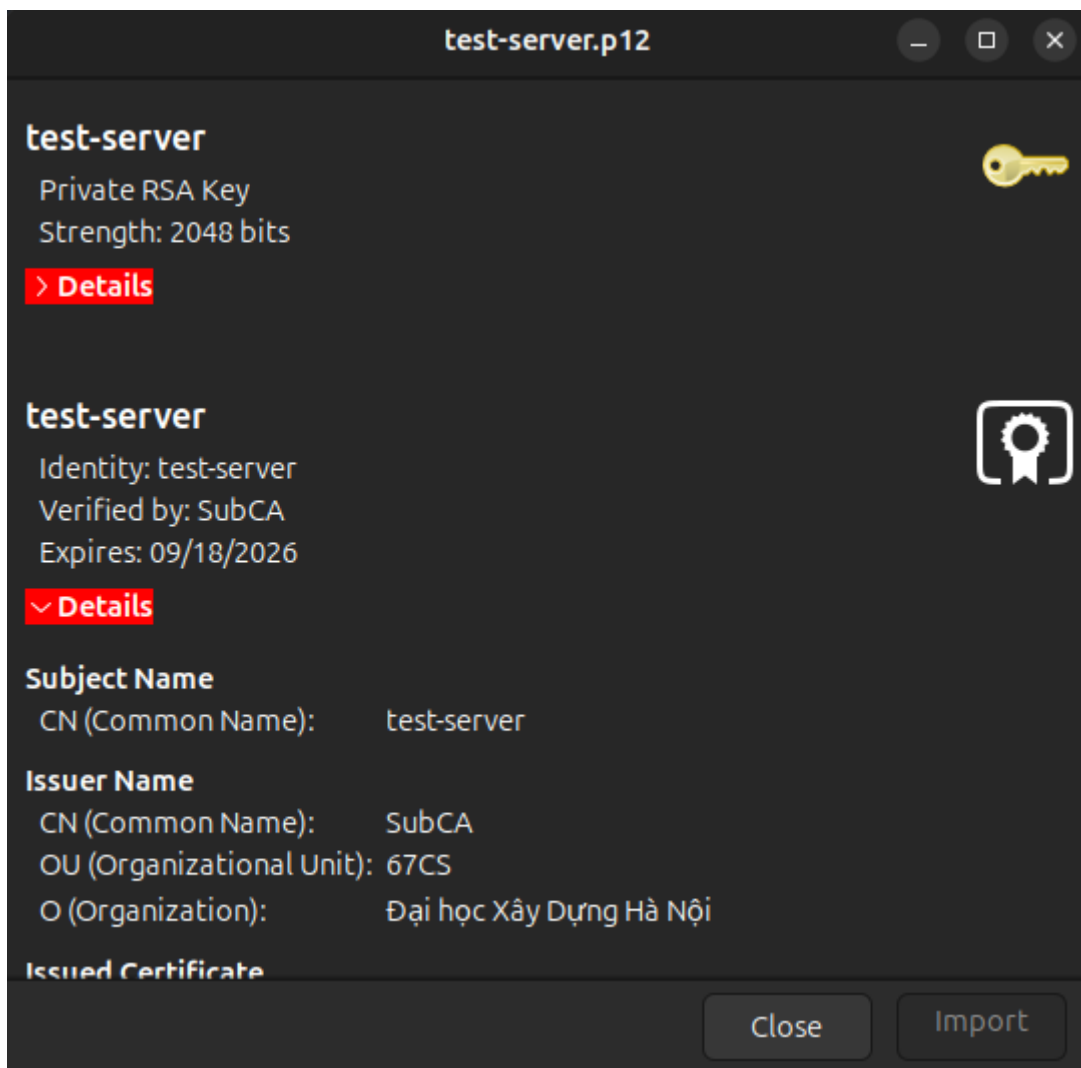
Download PKCS#12

Download BCFKS

Download PEM

Hình 33: Tải thông tin về

Sau khi tải chứng chỉ về và nhập mật khẩu đã tạo



Hình 34: Tải chứng chỉ test-server.p12 về và unlock bằng mật khẩu vừa tạo ở bước trên

6. Cấu hình Client Profiles

Chọn CA Functions -> Certificate Profiles

Tạo ClientProfiles và Edit



Hình 35: Tạo ClientProfiles

Chọn loại End Entity, mã hóa ECDSA độ dài 256 bit và có hiệu lực 1 năm (1y)

Back to Certificate Profiles	
Certificate Profile ID	328528097
Type	☒ End Entity ☐ Sub CA ☐ Root CA
Available Key Algorithms	ECDSA RSA Ed25519 Ed448 FALCON-512 FALCON-1024 ML-KEM-512 ML-KEM-768 ML-KEM-1024 ML-DSA-44 ML-DSA-65 ML-DSA-87
Available ECDSA curves	Any allowed by bit lengths B-163 / sect163r2 B-233 / sect233r1 B-283 / sect283r1 B-409 / sect409r1
Available Bit Lengths	239 bits 256 bits 257 bits 281 bits 282 bits

Hình 36: Chỉnh sửa ClientProfiles vừa tạo

Tại Key Usage chọn Digital Signature và Key encipherment, tại Extended Key Usage chọn Client Authentication

Key Usage	☒ Use... ☒ Critical ☐ Forbid encryption usage for ECC keys Key Usage: ☒ Digital Signature ☐ Data encipherment ☐ CRL sign ☐ Non-repudiation ☐ Key agreement ☐ Encipher only ☒ Key encipherment ☐ Key certificate sign ☐ Decipher only
Extended Key Usage	☒ Use... ☐ Critical Any Extended Key Usage CSN 369791 TLS client CSN 369791 TLS server Client Authentication Code Signing EAP over LAN (EAPOL) EAP over PPP ETSI TSL Signing Email Protection ICAO Deviation List Signing

Hình 37: Chỉnh sửa ClientProfiles vừa tạo

Chọn CA

Available CAs	Any CA ManagementCA RootCA SubCA
Publishers	

Hình 38: Chọn CA

Nhấn Save để lưu cài đặt

7. Phát hành chứng thư số cho Client

Chọn RA Functions -> End Entity Profiles

Thêm mới một End Entity Profiles

Add End Entity Profile

Hình 39: Thêm mới một End Entity Profiles

Chọn ClientEntity và Edit

Chọn hồ sơ chứng chỉ mặc định là ClientProfiles vừa cấu hình ở trên, tiếp theo chọn CA mặc định là SubCA, khóa ở đây do người dùng tạo

Main Certificate Data		
Default Certificate Profile	ClientProfiles ▼ ClientProfiles ENDUSER OCSPSIGNER SERVER SSLServerCertificateProfile SUBCA	
Available Certificate Profiles		
Default CA	SubCA ▼ Any CA ManagementCA RootCA SubCA	
Available CAs	Modifying available CAs may affect roles access to this profile	
Default Token	User Generated ▼ User Generated P12 file BCFKS file JKS file PEM file	
Available Tokens		

Hình 40: chỉnh sửa End Entity Profiles

Lưu End Entity Profiles

Chọn RA Web, chọn Make New Request trong Request new certificate



Hình 41: EJBCA RA

Chọn ClientEntity và tạo cặp khoá bởi CA

Select Request Template

Certificate Type
ClientEntity ▼

Key-pair generation ☒ By the CA
☐ Provided by user
☐ Postpone

Show details

Hình 42: Chọn ClientEntity và tạo cặp khoá bởi CA

Điền các thông tin CN, username, enrollment code và email

Provide request info

Required Subject DN Attributes

Common Name (CN) *
test-client

Provide User Credentials

Username *
test_client

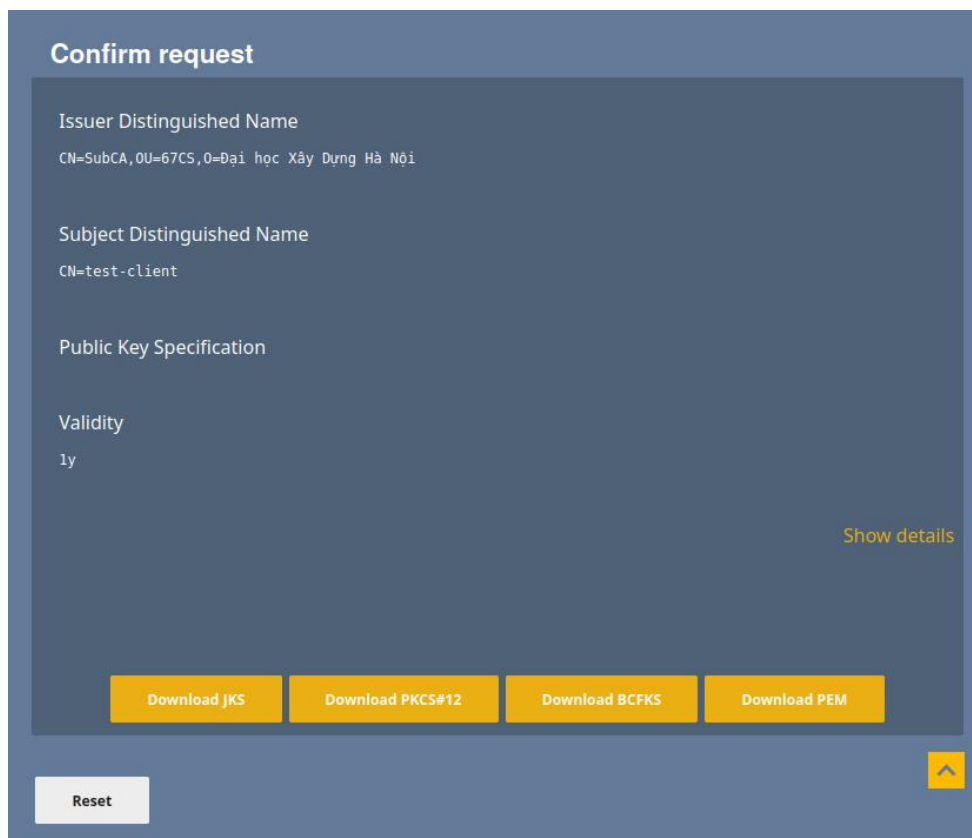
Enrollment code *
....

Confirm enrollment code *
....

Email
darkpunch09@gmail.com

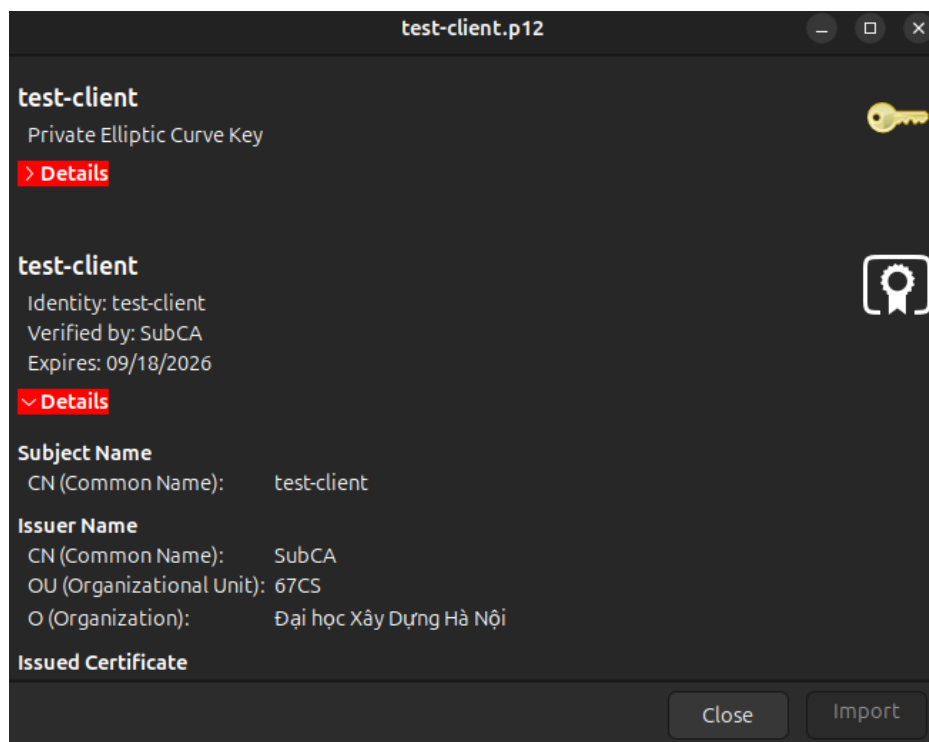
Hình 43: Điền các thông tin CN, username, enrollment code và email

Chọn Download PKCS#12 để tải thông tin về.



Hình 44: Tải thông tin về

Sau khi tải chứng chỉ về nhập mật khẩu đã tạo để mở



Hình 45: Sau khi tải chứng chỉ về nhập mật khẩu đã tạo để mở

III. Triển khai đăng ký và tạo chứng thư số

1. Cài đặt Apache Web Server

1.1. Cài đặt apache

Cài đặt Apache2

```
sudo apt update
```

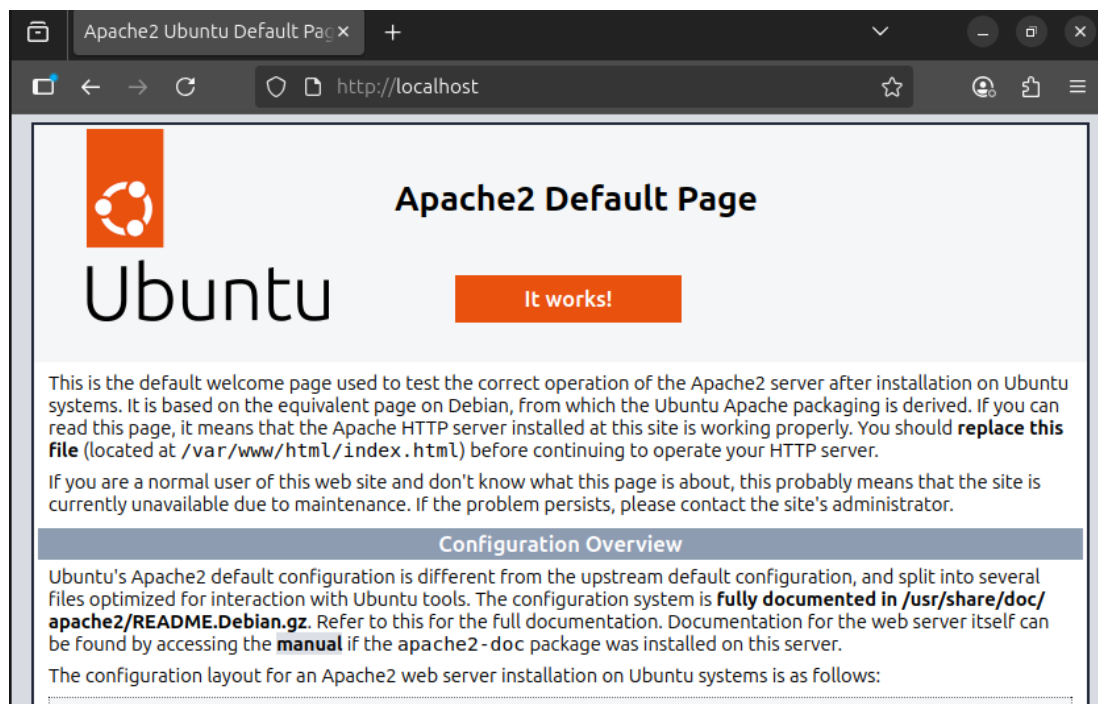
```
sudo apt install apache2
```

```
sudo systemctl start apache2
```

```
sudo systemctl enable apache2
```

```
sudo systemctl status apache2
```

Truy cập <http://localhost>



Hình 46: Cài Apache và truy cập localhost

1.2. Cấu hình SSL 1 chiều

Tạo thư mục certs chứa chứng chỉ dạng .p12 và thực hiện trích xuất khóa và chứng chỉ đối với chứng chỉ test-server.p12


```

hoangtranhuyhoang@hoanghoangubuntu:~$ cd certs/
hoangtranhuyhoang@hoanghoangubuntu:~/certs$ openssl pkcs12 -in test-server.p12 -
out server.key -nodes -nocerts
Enter Import Password:
hoangtranhuyhoang@hoanghoangubuntu:~/certs$ openssl pkcs12 -in test-server.p12 -
out server.crt -nokeys
Enter Import Password:
hoangtranhuyhoang@hoanghoangubuntu:~/certs$ █

```

Hình 47: Cấu hình SSL 1 chiều

Kết quả thu được:

server.key: private key

server.cert: public certificate của server

Cấu hình Apache sử dụng SSL

Kích hoạt module SSL trong Apache

```

hoangtranhuyhoang@hoanghoangubuntu:~$ sudo a2enmod ssl
Considering dependency mime for ssl:
Module mime already enabled
Considering dependency socache_shmcb for ssl:
Module socache_shmcb already enabled
Module ssl already enabled
hoangtranhuyhoang@hoanghoangubuntu:~$ sudo systemctl restart apache2
hoangtranhuyhoang@hoanghoangubuntu:~$ █

```

Hình 48: Kích hoạt module SSL trong Apache

Chỉnh sửa cấu hình VirtualHost

cd /etc/apache2/sites-available/

sudo nano default-ssl.conf

```

GNU nano 7.2                                default-ssl.conf
<VirtualHost *:443>
    ServerName www.jayehoang.com
    ServerAdmin webmaster@localhost

    DocumentRoot /var/www/html

    # Available loglevels: trace8, ..., trace1, debug, info, notice, warn,
    # error, crit, alert, emerg.
    # It is also possible to configure the loglevel for particular
    # modules, e.g.
    #LogLevel info ssl:warn

    ErrorLog /var/log/apache2/error.log
    CustomLog /var/log/apache2/ssl_access.log combined

    # For most configuration files from conf-available/, which are
    # enabled or disabled at a global level, it is possible to
    # include a line for only one particular virtual host. For example the
    # following line enables the CGI configuration for this host only
    # after it has been globally disabled with "a2disconf".

^G Help      ^O Write Out ^W Where Is  ^K Cut       ^T Execute   ^C Location
^X Exit      ^R Read File ^N Replace   ^U Paste     ^J Justify   ^_ Go To Line

```

Hình 49: Chỉnh sửa cấu hình VirtualHost

Tải về file RootCA gốc từ giao diện RA Web

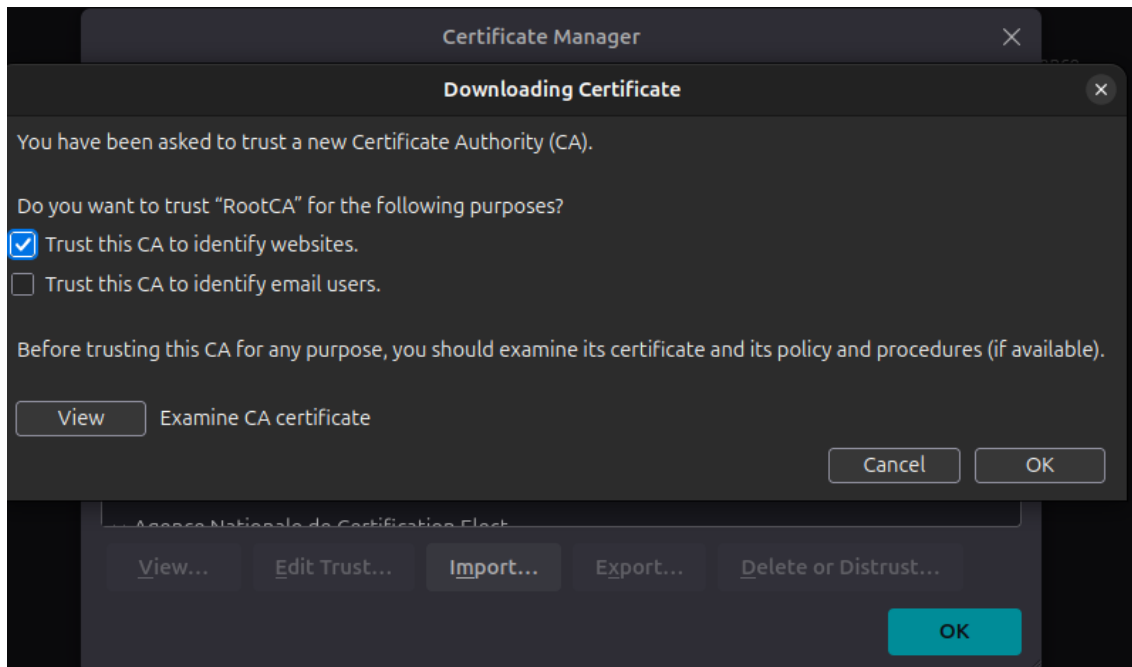
CA Certificates and CRLs

Certificate Authority	CRL	Certificate	Certificate chain ¹	Browser import
ManagementCA UID=c-0nz0dapezoslji8f,CN=ManagementCA,O=EJBCA Container Quickstart	Full	PEM DER	PEM JKS PKCS#7	Firefox Edge
RootCA CN=RootCA,O=67CS,O=Âi ỉi hăc XẤy Dăzng HẢ Năi	Full	PEM DER	PEM JKS PKCS#7	Firefox Edge
SubCA CN=SubCA,O=67CS,O=Đại học Xây Dựng Hà Nội	Full	PEM DER	PEM JKS PKCS#7	Firefox Edge

¹ Java Key Store (JKS) password is set to 'changeit'.

Hình 50: Tải về file RootCA gốc từ giao diện RA Web

Mở Firefox -> Settings -> Privacy & Security -> View Certificates -> Authorities -> Import RootCA và chọn tin tưởng



Hình 51: Download Certificate

Truy cập vào localhost với cổng tương ứng sẽ thấy biểu tượng khoá màu xanh (Not Secured)

2. Cấu hình SSL 2 chiều

Từ file chứng thư số client đã tải về thực hiện trích xuất chứng chỉ
`openssl pkcs12 -in Client.p12 -out client.crt -nokeys`

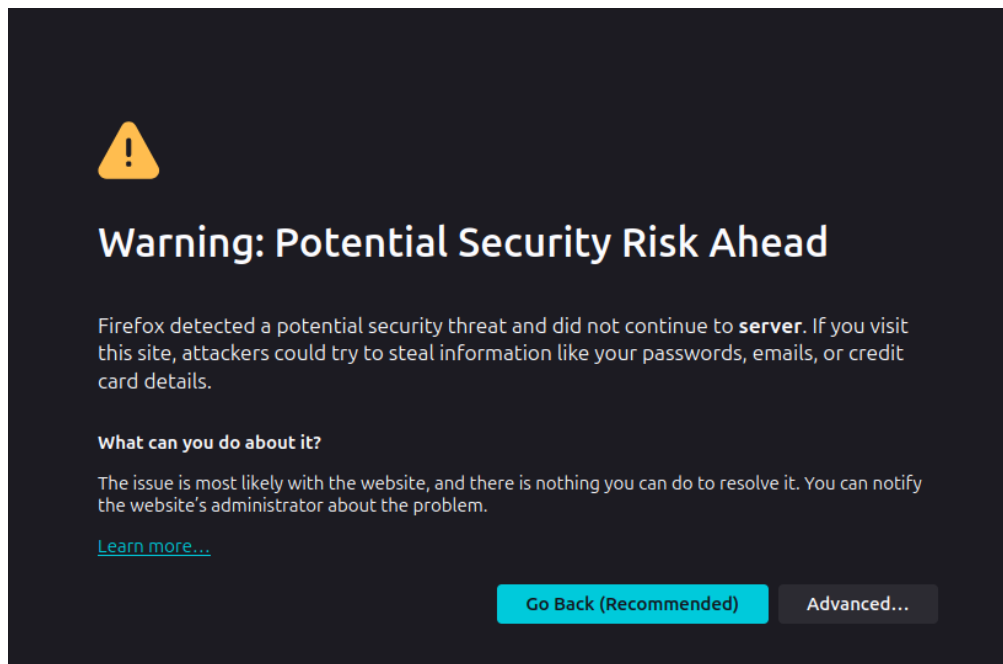
Truy cập đường dẫn `cd /etc/apache2/sites-available/` chỉnh sửa file `000 default.conf` trong đó file `client.crt` được trích xuất ở trên

```
hoangtranhuyhoang@hoanghoangubuntu: ~  
GNU nano 7.2 /etc/apache2/sites-available/000-default.conf *  
<VirtualHost *:8082>  
    ServerName localhost  
    DocumentRoot /var/www/html  
  
    SSLEngine on  
    SSLCertificateFile /etc/ssl/certs/server.crt  
    SSLCertificateKeyFile /etc/ssl/private/server.key  
  
    SSLCACertificateFile /etc/ssl/certs/client.crt  
  
    <Directory /var/www/html>  
        Options Indexes FollowSymLinks  
        AllowOverride All  
        Require all granted  
    </Directory>  
  
    ErrorLog ${APACHE_LOG_DIR}/ssl_error.log  
    CustomLog ${APACHE_LOG_DIR}/ssl_access.log combined  
</VirtualHost>  
  
^G Help      ^O Write Out ^W Where Is  ^K Cut       ^T Execute   ^C Location  
^X Exit      ^R Read File ^\ Replace   ^U Paste     ^J Justify   ^_ Go To Line
```

Hình 52: Chỉnh sửa cấu hình VirtualHost để cấu hình 2 chiều

Lưu và khởi động lại apache2

Truy cập lại trang localhost với port trước đó sẽ bị chặn truy cập (Not Secured)



Hình 53: Cảnh báo của firefox

Để truy cập được cần import file chứng chỉ và khóa của client vào Firefox.

Chọn OK và trở lại trang web sẽ nhận yêu cầu gửi chứng chỉ lên server, chọn chứng chỉ client.

Kết quả khi này sẽ là biểu tượng khoá màu xanh (Secured) và sẽ truy cập được web với kết nối an toàn.

CHƯƠNG 3: KẾT LUẬN

Trong đề tài này, nhóm đã tìm hiểu và bước đầu triển khai hệ thống chứng thực số sử dụng **EJBCA** kết hợp với **Apache Web Server** với mục tiêu cấu hình bảo mật kết nối **SSL/TLS**. Trong quá trình thực hiện, nhóm đã hoàn thành một số nội dung quan trọng, bao gồm:

1. **Cài đặt và cấu hình EJBCA** trên môi trường Docker, tạo được **RootCA** và **SubCA** để quản lý chứng chỉ số.
2. **Tìm hiểu cơ chế hoạt động của SSL/TLS**, phân biệt rõ sự khác nhau giữa **SSL một chiều** và **SSL hai chiều**, đồng thời nắm được lý thuyết về cách triển khai hai hình thức này trong thực tế.
3. **Cấu hình và tích hợp Apache Web Server với chứng chỉ từ EJBCA**, bước đầu thiết lập được môi trường chạy HTTPS và kiểm thử thành công một phần quy trình phát hành, quản lý chứng chỉ.

Tuy nhiên, nhóm **chưa hoàn thiện hoàn toàn việc kết nối SSL một chiều và hai chiều**. Trong quá trình thử nghiệm, vẫn gặp một số vấn đề kỹ thuật như:

- Chứng chỉ chưa được Firefox hoặc các trình duyệt khác tin cậy đầy đủ.
- Apache chưa gửi được đầy đủ chuỗi chứng chỉ (chain) trong một số trường hợp.
- Xung đột cấu hình khi chạy đồng thời EJBCA và Apache, gây khó khăn trong việc kiểm thử.

Mặc dù chưa đạt được mục tiêu cuối cùng, đề tài đã giúp nhóm tích lũy được nhiều kiến thức về **chứng thực số, mô hình PKI**, và các thao tác quản lý CA/SubCA. Đây sẽ là nền tảng quan trọng để nhóm tiếp tục hoàn thiện hệ thống trong giai đoạn tiếp theo.